

※본 보고서의 전부나 일부를 인용 시, 반드시

[자료 : 미래창조과학부, 한국인터넷진흥원(KISA)]를 명시하여 주시기 바랍니다.



민간부문 침해사고 대응 안내서



미래창조과학부

KISA 한국인터넷진흥원



목차 | CONTENTS

제1장 개요



- 1. 배경 6
- 2. 목적 및 구성 7

제3장 침해사고 조치 가이드



- 1. 침해사고 유형 24
- 2. 침해사고 점검항목 및 조치방안 (개인) 26
- 3. 침해사고 점검항목 및 조치방안 (기업) 28
- 4. 시스템 유형별 보안 조치 방안 33



민간부분 침해사고 대응안내서



제2장 사이버 침해사고 신고

- 1. 사이버 침해사고 발생 시 신고 10
- 2. 개인정보 유출사고 발생 시 신고 16



부록

- 1. 사이버 위기 경보 48
- 2. WHISTL, Rootkit Hunter, Check Rootkit 사용법 54
- 3. 주요용어 정리 55

민간부분 침해사고 대응안내서



01

제장 개요

- 1. 배경 6
- 2. 목적 및 구성 7



제1장 개요

1. 배경

우리나라는 2015년 국제전기통신연합(ITU)이 평가한 ICT 발전지수에서 1위를 차지하며 명실상부 세계 최고의 ICT 강국으로 평가 받고 있으며, 초고속 인터넷 보급률 또한 경제협력개발기구(OECD) 국가 중 1위를 차지하고 있다.

또한 2016년 우리나라 인터넷 이용률은 85.1%, 스마트폰 보유율은 86.4%로 꾸준히 증가하고 있으며, 모든 국민이 언제 어디서나 인터넷과 연결되는 초연결 시대로 진입하고 있다.

이제 인터넷을 기반으로 한 정보통신은 선택이 아닌 우리 생활과 밀접한 생존에 직결되는 영역이며, 오늘날 국가 경쟁력을 좌우하고 있다고 해도 과언이 아니다.

이와 같은 인터넷의 생활화와 함께 해킹, 악성코드, 서비스 거부(DDoS) 등 인터넷 침해사고의 공격 유형도 갈수록 다양화되고 있으며 매년 증가추세를 보이고 있다. 또한, 개인정보 침해, 산업기밀 유출, 사이버 범죄, 사이버 테러 등 사이버공간에 대한 위협은 다양해지고, 그에 따른 피해도 커지고 있다.

인터넷 침해사고는 이제 특정 개인, 기업의 문제가 아닌 사회적, 국가적, 세계적 이슈가 되고 있다. 이처럼 인터넷 등 정보통신의 발달에 따른 생활의 편리함 등 순기능과 함께 해킹 등과 같은 역기능도 피할 수 없는 상황이다. 날로 증가하는 사이버 위협에 지속적으로 대비하고, 현재의 침해사고 예방 및 대응 수준을 더욱 높여 개인, 기업, 국가의 안전을 보장해야 할 것이다.



2. 목적 및 구성

본 안내서는 기업의 정보보호담당자 및 개인 인터넷 이용자들에게 인터넷 침해사고의 예방 및 대응요령을 제공한다. 안내서의 적용범위는 민간부문이며 구체적인 대상은 정보통신서비스 제공자, 인터넷서비스제공자(ISP) 및 집적정보통신시설 사업자(IDC), 기업(정보보호 담당자 또는 서버/네트워크 관리자)을 비롯하여 개인, PC방 등 인터넷 가입자이다.

- 〈제1장 개요〉는 안내서의 이해를 돕기 위해 배경, 목적 및 구성을 설명하였다.
- 〈제2장 사이버 침해사고 신고〉는 침해사고가 발생하거나 인지한 경우, 정보통신망 이용촉진 및 정보보호 등에 관한 법률(이하 정보통신망법)에 의거하여 즉시 그 사실을 미래창조과학부나 한국인터넷진흥원에 신고하여야 하는 의무와 신고 대상, 신고 절차 등에 대해 설명하였다.
- 〈제3장 침해사고 조치 가이드〉 부분에서는 구체적으로 침해사고 발생 시 대응절차, 사고 유형별 시스템 점검항목 및 조치 방안, 웹 서버 취약점 조치 방안, 네트워크 취약점 조치 방안, DB 취약점 조치 방안, 어플리케이션 취약점 조치 방안에 대한 정보를 제공하는데 주안점을 두었다.
- 부록에서는 사이버 위기 경보의 정의, 경보발령 주체 및 절차에 대한 체계 설명, 정상-관심-주의-경계-심각 단계 위기경보 수준별 조치사항 및 본문에서 다루지 못한 WHISTL, Rootkit Hunter, Check Rootkit 사용법과 인터넷 침해관련 주요 용어를 별도로 수록하였다.

민간부분 침해사고 대응안내서



02

제2장 사이버 침해사고 신고

- 1. 사이버 침해사고 발생 시 신고 10
- 2. 개인정보 유출사고 발생 시 신고 16



제2장 사이버 침해사고 신고

1. 사이버 침해사고 발생 시 신고

가. 침해사고 정의

정보통신망법 제2조 제1항 제7호에 따르면, “침해사고”란 “해킹, 컴퓨터바이러스, 논리폭탄, 메일폭탄, 서비스 거부 또는 고출력 전자기파 등의 방법으로 정보통신망 또는 이와 관련된 정보시스템을 공격하는 행위를 하여 발생한 사태”를 의미한다.

예를 들어 DDoS 공격에 의한 운영 서비스의 지연 또는 장애 발생, 해킹 공격 및 악성코드 감염에 의한 정보 유출, 시스템 파괴, 공격 경유지 이용, 위변조 등 피해가 발생한 모든 사고를 침해사고로 볼 수 있다.

나. 관련 법률

정보통신서비스 제공자 및 집적정보통신 사업자는 해킹, 악성코드, DDoS 등의 사이버 공격으로 인한 침해사고가 발생하거나 인지한 경우, 정보통신망 이용촉진 및 정보보호 등에 관한 법률(이하 정보통신망법)에 의거하여 그 사실을 즉시 미래창조과학부나 한국인터넷진흥원에 신고하여야 한다.

정보통신망 이용촉진 및 정보보호 등에 관한 법률 제48조의3(침해사고의 신고 등)에 의거하여 정보통신서비스 제공자, 집적 정보통신시설 사업자는 침해사고가 발생하면 즉시 그 사실을 미래창조과학부장관이나 한국인터넷진흥원에 신고하여야 한다.

※ “즉시”의 사전적인 의미는 “어떠한 일이 행하여지는 바로 그때”를 의미한다. 그러나 논리적으로 신고의무자의 사고발생에 대한 인지가 필요하므로 “침해사고가 발생하는 바로 그때”가 아니라 “침해사고를 인지한 때”로 볼 수 있다.

침해사고가 발생한 사실을 알고도 미래창조과학부나 한국인터넷진흥원에 신고하지 않을 경우, 정보통신망법 위반으로 1천만원 이하의 과태료가 부과되므로 반드시 신고하여야 한다.

정보통신망 이용촉진 및 정보보호 등에 관한 법률 제76조(과태료) 제3항에 의거하여 1천만원 이하의 과태료를 부과

나. 침해사고 신고 의무 대상

침해사고 신고 의무 대상은 영리를 목적으로 인터넷 서비스를 운영하는 모든 사업자(기업)가 해당된다.

영리를 목적으로 한다는 것은 재산상 이익을 취득하거나 이윤을 추구하려는 목적이 있음을 의미하며, 인터넷 상에서 상업적인 목적으로 웹사이트를 개설·운영하거나 인터넷 기반 서비스를 제공하는 경우 모두 해당한다.

예를 들어, 웹호스팅업체, 인터넷쇼핑몰업체, 경매·커뮤니티·미니홈피·블로그 서비스 제공자, P2P 등 인터넷 기반 서비스 제공 사업자 대부분이 해당된다고 할 수 있다.

‘정보통신망’에서 정보통신서비스 제공자란 전기통신사업법 규정에 의한 ① 전기통신사업자와 ② 영리를 목적으로 전기통신 사업자의 전기통신역무를 이용하여 정보를 제공하거나 정보의 제공을 매개하는 자를 말한다.

전기통신사업자는 「전기통신사업법」의 규정에 따른 허가·등록·신고 절차를 거친 기간통신사업자, 별정통신사업자, 부가통신사업자를 의미한다.

기간통신사업자는 초고속인터넷기업, 이동통신사 등 유·무선 통신사업자를 의미한다

별정통신사업자는 앞서 말한 기간통신사업자의 전기통신회선설비 등을 이용하여 기간통신역무를 제공하거나, 법령에서 정하는 바에 따라 국내에서 전기통신역무를 제공하는 사업자로서, 국제전화서비스, 재판매 사업자 등이 해당된다.

부가통신사업자는 기간통신사업자의 전기통신회선설비를 이용하여 기간통신업무 이외의 전기통신역무를 제공하는 사업자로서, 포털사이트·게임사이트·온라인쇼핑몰·커뮤니티·미니홈피·블로그 등 일반적인 인터넷 웹사이트를 운영하는 사업자가 해당된다.

특수한 유형의 부가통신사업자는 다른 사람 상호간에 컴퓨터를 이용하여 정보나 파일 등을 저장, 전송을 주된 목적으로 하는 사업자로서, 웹하드나 P2P사이트 등을 운영하는 사업자가 해당된다.

집적정보통신시설 사업자는 법 제2조제2호에 따른 정보통신서비스를 제공하는 고객의 위탁을 받아 컴퓨터장치 등 전자정부법 제2조제13호에 따른 정보시스템을 구성하는 장비(이하 “정보시스템 장비”라 한다)를 일정한 공간(이하 전산실이라 한다)에 집중하여 관리하는 시설 사업자를 말한다.

집적정보통신시설 사업자는 자사 고객사의 침해사고 발생 사실을 알게 된 경우, 그 사실을 즉시 미래창조과학부나 한국인터넷진흥원에 신고하여야 한다.

정보통신서비스 제공자의 구체적인 범위는 한국인터넷진흥원에서 발간한 ‘정보통신서비스 제공자를 위한 개인정보보호 법령 해설서’를 참고하면 된다.

정보통신서비스 제공자를 위한 개인정보보호 법령 해설서는 KISA 개인정보보호포털홈페이지(www.i-privacy.kr) 자료실에서 확인이 가능하다.

다. 신고 절차

신고는 침해사고를 인지한 즉시 이루어져야 하며, 한국인터넷진흥원의 보호나라&KrCERT 홈페이지 또는 118 상담센터에 신고하도록 한다.

- 한국인터넷진흥원 보호나라&KrCERT 홈페이지 : <http://www.boho.or.kr>
- 민원상담 110 : ☎ (국번없이) 110, 전화 연결 후 118 상담센터 연결을 요청

홈페이지를 통한 침해사고 신고 절차는 다음과 같다.

- ① 보호나라&KrCERT 홈페이지에 접속하여, 화면 중앙에 위치한 신고센터의 '해킹사고'메뉴를 클릭한다.
※ 별도의 로그인 절차는 필요하지 않다.

The screenshot shows the KISA 보호나라 & KrCERT homepage. At the top, there's a navigation bar with links like '사이버위험', '보안서비스', '다운로드', '상담 및 신고', '자료실', '랜섬웨어', and 'KrCERT/CC'. The main banner features a warning about phishing emails and a notice about a recent phishing email campaign. Below the banner, there's a section titled '오늘의 사이버 위협?' (Today's Cyber Threats) with a table showing the number of phishing emails, suspicious emails, and phishing sites. To the right, there's a '주요 키워드 랭킹' (Main Keyword Ranking) section. The '신고센터 118' (Report Center 118) section is highlighted, showing a grid of incident types: '해킹사고' (Hacking Incident), '피싱사고' (Phishing Incident), '웬/바이러스' (Worm/Virus), '발신번호 거짓표시' (False Caller ID), 'S/W 신규 취약점' (New Software Vulnerability), and '해킹/바이러스 상담' (Hacking/Virus Consultation). The '해킹사고' menu is highlighted with a red box.

〈그림 2-1〉 KISA 보호나라 & KrCERT 홈페이지 해킹사고 신고 메뉴

② 해킹사고 신고 양식에 따라 사고의 내용을 작성한 후 ‘접수하기’ 버튼을 클릭한다.

해킹 사고

[홈](#) > [상담 및 신고](#) > [해킹 사고](#)

대검찰청, 경찰청, 인터넷진흥원, 금융기관 등을 사칭하는 보이스피싱, 피싱사이트, 피싱 문자로 인한 금전적 피해가 발생하고 있습니다. 사이트 접속 시 바로 개인정보를 입력하지 말고 사이트 주소를 확인하시고 주의해 주십시오

해킹 사고신고 접수를 위한 개인정보 수집 · 이용

1. 개인정보의 수집 · 이용 목적

수집하는 개인정보는 해킹 사고신고 확인을 위한 목적으로만 사용되며, 관련 담당자를 제외하고는 함부로 열람할 수 없습니다.

2. 수집하려는 개인정보의 항목

한국인터넷진흥원은 개인정보보호법 제15조에 따라 개인정보의 수집 · 이용 시 본인의 동의를 얻어야 하는 정보를 수집하고 있습니다. 수집 · 이용 목적에 따라 수집하고 있는 항목은 아래와 같습니다.

- 필수항목 : 성명, 이메일, 연락처
- 선택사항 : 신고기관종류, 신고기관명, 피해IP, 공격IP

3. 개인정보의 보유 및 이용 기간

수집된 개인정보는 “한국인터넷진흥원 민원처리 등에 관한 규칙”에 근거하여 3년간 보유하고 즉시 파기합니다.

이용자는 동의를 거부할 수 있습니다. 다만, 이 경우 해킹 사고신고 서비스의 이용이 불가능 합니다.

위 사항에 동의 하십니까?

개인정보수집/이용 동의 클릭

☒ 동의함 ☐ 동의하지않음

별표 (*) 가 표시된 항목은 필수 입력 항목이므로 반드시 입력해 주십시오.

* 성명	신고자 성명	* 이메일	신고자의 이메일 주소
* 연락처	번호선택 - - 신고자의 연락 가능한 휴대폰 번호 또는 전화번호		
신고기관종류	신고기관 선택	신고기관명	신고기관의 이름
* 운영체제	운영체제 선택	피해 서버의 운영체제 정보	
피해IP	피해서버의 IP	피해PORT	피해를 입은 서비스 포트
공격IP	공격자의 IP 정보 (알고 있을 경우 기재)		
침해발생시간	년 월 일 시 분 침해사고의 최초 발생시간		
* 제목			
* 신고내용	피해내역을 최대한 자세히 기재		
관련파일첨부	파일 선택 선택된 파일 없음 피해내역 사진, 피해서버의 로그 파일 등 관련 파일 업로드 ※ 첨부파일의 크기는 20MB 이하로 제한됩니다		

접수하기

취소

〈그림 2-2〉 KISA 보호나라 & KrCERT 홈페이지 해킹사고 신고 입력 화면

라. 침해사고에 대한 기술지원 요청

침해사고 신고 후 사고원인 분석 및 조치를 위한 기술지원이 필요할 경우 한국인터넷진흥원 보호나라 & KrCERT 홈페이지 또는 118 상담센터를 통해 기술지원을 받을 수 있다.

- KISA 보호나라 & KrCERT 홈페이지 : <http://www.boho.or.kr>
- 민원상담 110 : ☎ (국번 없이) 110, 전화 연결 후 118 상담센터 연결을 요청

개 인

악성코드 감염, 해킹 등을 통해 일반 인터넷 사용자에게 사기, 개인정보 유출 등 피해가 발생했을 경우 한국인터넷진흥원의 보호나라 & KrCERT 홈페이지 및 118 사이버 상담센터에 신고하여 문제 해결을 위한 상담 및 지원을 받을 수 있다.

- 한국인터넷진흥원 보호나라 & KrCERT 홈페이지 : <http://www.boho.or.kr>
- 민원상담 110 : ☎ (국번 없이) 110, 전화 연결 후 118 상담센터 연결을 요청

KISA 보호나라 & KrCERT

인터넷침해사고 경보단계 |
 관심 |
 사이버위협 |
 보안서비스 |
 다운로드 |
 상당 및 신고 |
 자료실 |
 랜섬웨어 |
 KrCERT/CC

사이버사기 대처요령

사이버 사기가 지속 발생하고 있어 공공기관 및 기업을 사칭한
사이버 사기의 주요 내용과 대처 요령을 Q&A 형식으로 안내해드립니다



● ● ● ● ● ||

오늘의 사이버 위협 ?

Today : 2016.11.30

악성코드 발견 홈페이지	6 (개) ▾
신종 스미싱 악성 앱	5 (개) ▲
피싱 · 피람 차단 사이트	56 (개) ▲

주요 키워드 랭킹

ActiveX , SafePC , SafeUSB , 닉스텍 , 스마트폰 , 백도어 , NTP , 업데이트 , 취약점 , 스파이웨어 , DoS , ICMP 프로토콜 , VMware , 메모리 취약점 , PC방 , 가이드 , 침해사고 예방 , OpenSSL , PwnFest , VMware

신고센터 118 해킹, 피싱 등의 보안 피해를 당하셨나요?

해킹사고

해킹을 당하셨다면 지금 바로 신고하세요

피싱사고

피싱 메일이나 전화를 받으셨다면 신고하세요

웬/바이러스

PC가 바이러스에 감염 되셨다면 신고하세요

발신번호 거짓표시

발신번호가 거짓 표시(번갈) 되었다면 신고하세요

S/W 신규 취약점

소프트웨어 신규 보안 취약점 신고 포상제를 실시합니다

해킹/바이러스 상담

해킹/바이러스에 관해 상담 및 신고를 받습니다

〈그림 2-3〉 한국인터넷진흥원 보호나라&KrCERT 홈페이지 신고

각종 침해사고로부터 안전하게 인터넷을 사용하기 위해 사용자는 보안수칙을 준수하는 것이 바람직하다. 한국인터넷진흥원은 안전한 인터넷 사용을 위한 5대 보안수칙 및 스마트폰 사용 10대 보안수칙을 권고하고 있다.

안전한 인터넷 사용을 위한 5대 보안수칙

- ① 모든 소프트웨어는 최신버전으로 업데이트하여 사용합니다.
- ② 백신소프트웨어를 반드시 설치하고, 최신버전으로 업데이트 합니다.
- ③ 출처가 불명확한 이메일과 URL 링크는 실행하지 않습니다.
- ④ 파일 공유 사이트 등에서 파일 다운로드 및 실행에 주의합니다.
- ⑤ 중요 자료는 정기적으로 백업합니다.

스마트폰 사용 10대 보안수칙

- ① 스마트폰 잠금화면은 반드시 보안설정(패턴, 지문인식 등)을 적용합니다.
- ② 앱 설치시 위치정보, 주소록 정보 등 불필요한 권한을 요청하는지 확인합니다.
- ③ 백신앱은 반드시 설치하여 사용합니다.
- ④ 앱은 공식 앱마켓에서만 다운로드 합니다.
- ⑤ 스마트폰 교체 전 개인정보는 삭제합니다.
- ⑥ 탈옥, 루팅 등 기본 운영체제를 변경하지 않습니다.
- ⑦ 은행보안카드 등 중요한 개인정보는 가급적 스마트폰에 저장하지 않아야 합니다.
- ⑧ 보안이 적용되지 않은 Wi-Fi는 사용에 주의합니다.
- ⑨ 블루투스, Wi-Fi 기능은 평소 꺼두는 것이 좋습니다.
- ⑩ 출처가 불분명한 문자나 URL 링크는 실행하지 않습니다.

2. 개인정보 유출사고 발생 시 신고

가. 관련 법률

정보통신서비스 제공자는 개인정보 침해사고 발생 시 방송통신위원회 또는 한국인터넷진흥원에 개인정보 유출을 반드시 신고하여야 한다.

정보통신망 이용촉진 및 정보보호 등에 관한 법률 제27조의3(개인정보 유출등의 통지·신고)에 의거하여 정보통신서비스 제공자등은 개인정보의 분실·도난·유출 사실을 안 때에는 지체 없이 다음 각 호의 모든 사항을 해당 이용자에게 알리고 방송통신위원회 또는 한국인터넷진흥원에 신고하여야 하며, 정당한 사유 없이 그 사실을 안 때부터 24시간을 경과하여 통지·신고해서는 아니 된다.

정보통신서비스 제공자는 개인정보의 분실·도난·유출 사실을 안 때에는 지체 없이 방송통신위원회 신고와는 별도로 이용자에게도 통지하여야 한다.

통지 또는 신고하지 않을 경우 3천만 원 이하의 과태료가 부과될 수 있다.

정보통신망 이용촉진 및 정보보호 등에 관한 법률 제76조 제1항 2의 3호(과태료)에 의거하여 3천만원 이하의 과태료를 부과

※ 통지 사항

1. 유출등이 된 개인정보 항목
2. 유출등이 발생한 시점
3. 이용자가 취할 수 있는 조치
4. 정보통신서비스 제공자등의 대응 조치
5. 이용자가 상담 등을 접수할 수 있는 부서 및 연락처

※ 통지 방법

전자우편·서면·모사전송·전화 또는 이와 유사한 방법

나. 신고 절차

사고 발생을 인지한 시간으로부터 24시간 내 반드시 신고하여야 하며, 서면 또는 한국인터넷진흥원의 온라인 개인정보보호 포털 홈페이지를 통해 인터넷 또는 서면으로 신고하도록 한다.

- 한국인터넷진흥원 온라인 개인정보보호 포털 : <http://www.i-privacy.kr>

구분		내용
신고대상		건수에 관계없이 신고
신고내용		1. 유출 등이 된 개인정보 항목 2. 유출 등이 발생한 시점 3. 이용자가 취할 수 있는 조치 4. 정보통신서비스 제공자등의 대응 조치 5. 이용자가 상담 등을 접수할 수 있는 부서 및 연락처
신고시기		1. 정보통신서비스 제공자등이 유출 등의 사실을 인지한 시점에서 합리적인 이유 및 근거가 없는 한 즉시 신고 의무 발생 2. 추가 확인 사항은 확인되자마자 바로 신고
신고방법	서면신고	개인정보 유출신고서를 작성하여 전화, 팩스, 이메일, 우편으로 신고 ※ 이메일주소 : 118@kisa.or.kr 전화번호 : 국번 없이 110, 전화 연결 후 118 상담센터 연결을 요청 팩스번호 : 02-405-5229 우편주소 : (05717) 서울특별시 송파구 중대로 135 IT벤처타워 서관 4층 한국인터넷진흥원 개인정보점검팀
	인터넷신고	온라인 개인정보보호포털(http://www.i-privacy.kr)의 개인정보유출신고 페이지 이용

① 온라인 개인정보보호 포털 사이트에 접속하여 '개인정보유출신고' 메뉴를 클릭한다.

KISA 개인정보보호 포털

HOME 나의 주장내역 사이트맵

개인정보보호 소개 기술지원 개인정보 신고 개인정보보호 교육 자료실 정보광장

정보통신망법 개정내용안내
개인정보보호와 관련된 규정 및 주요내용

사업자
개인정보보호 이용수칙
사업자가 반드시 알아야 할 개인정보보호 수칙
[MORE]

이용자
기술지원
개인정보보호 기술지원 안내 서비스입니다.
[MORE]

개인정보 신고
개인정보 유출신고 안내입니다.
[MORE]

사업자 온라인교육
개인정보보호 교육과정
CEO/CPO 교육과정
업종별 교육과정
위치정보 교육과정
[MORE]

사업자 개인정보보호 이용수칙
사업자가 반드시 알아야 할 개인정보보호 수칙

스마트폰 이용자, 이것만은 지켜주세요!
개인정보보호 10대 수칙

정보통신망법 개정 안내
개인정보보호와 관련된 규정 및 주요 내용

공지 NOTICE

- 개인정보보호 최고 책임자(CEO-CPO) 2016-10-28
- 개인정보보호 최고 책임자(CEO-CPO) 2016-10-28
- 아시아 프라이버시 브릿지 포럼(Asia P 2016-10-28
- 광고성 정보 전송자 2년 마다 수신동의 여 2016-10-21
- 2016년 개인정보보호 유공자 표창 후보자 2016-10-12

뉴스 NEWS

- 행자부, 개인정보 수집 최소화 가이드 2016-11-30
- 정부, 구글 '지도 반출' 불허... "안보위협 2016-11-21
- 방통위-KISA, 정부3.0 경진대회에서 2016-11-11
- 개인정보 노출 위험 중고거래 사이트, 가이 2016-11-11
- KISA '개인정보 활용' 표준화기업 책 2016-11-11

〈그림 2-4〉 KISA 온라인 개인정보보호 포털 신고 메뉴

② 서면 신고는 양식에 따라 사고의 내용을 작성한 후 이메일, 팩스 또는 우편을 통해 접수한다.

사업자 개인정보유출신고서

(필수)가 표시되어있는 항목을 꼭 기재 부탁드립니다, 부족한 내용이 있을 경우 연락이 갈 수 있습니다.

기관명(필수)	신고기관의 이름		사업자번호(필수)	신고기관의 사업자번호	
사업자주소 (사업자등록기준)	신고기관의 주소		웹 사이트 주소	사고발생 웹 사이트의 주소	
유출된 개인정보의 항목 및 규모	사고발생 내역을 최대한 자세히 기재				
유출이 발생한 시점 및 경위					
이용자가 취할 수 있는 조치(필수)					
정보통신서비스 제공자들의 대응조치(필수)					
이용자가 상담 담당부서・담당자 및 연락처(필수)		성명	연락처	이메일	
	개인정보 보호책임자				
	개인정보 보호담당자				

※ 하단은 접수기관에서 기재하는 부분이므로 신고자는 기재하실 필요가 없습니다.

신고접수 기관	기관명(지역)	접수자명	연락처	이메일	접수일자

〈그림 2-5〉 서면 신고 양식

③ 인터넷 신고는 양식에 따라 사고의 내용을 작성한 후 신고 접수하기를 클릭한다.

개인정보 유출신고

• 개인정보 유출신고 작성 안내

- 개인정보 유출신고는 정보통신 서비스를 제공하는 사업자들을 대상으로 하는 신고제도입니다.
- 정보통신서비스 제공자들은 개인정보의 분실·도난·유출 사실을 안 때에는 지체 없이 방송통신위원회 신고와는 별도로 이용자에게도 통지하여야 합니다.
- ※ 관련근거 : 정보통신망 이용촉진 및 정보보호 등에 관한 법률 제27조의3 제1항
- * 이용자의 개인정보 침해에 대한 신고는 '개인정보침해신고센터(☎콜센터 118)를 이용부탁드립니다.

• 개인정보 유출신고 정보 입력

신고접수는 가급적 개인정보 취급자가 해주시기를 바랍니다. * 필수 입력 항목입니다.

기관명*	신고기관의 이름	사업자번호*	- - - 신고기관의 사업자번호												
사업자주소 (사업자등록기준)	신고기관의 주소	웹사이트 주소	사고발생 웹 사이트의 주소												
유출된 개인정보의 항목 및 규모(건수)*	사고발생 내역을 최대한 자세히 기재 0 / 4000bytes														
유출이 발생한 시점 , 유출 인지 시점 및 경위*	0 / 4000bytes														
이용자가 취할 수 있는 조치*	0 / 4000bytes														
정보통신서비스 제공자등의 대응조 치*	0 / 4000bytes														
이용자 상담 담당부 서 ·담당자 및 연락처*	<table><tr><td></td><td>성명</td><td>연락처(HP)</td><td>이메일</td></tr><tr><td>개인정보 보호책임자</td><td> </td><td> 선택 ▾ - - - </td><td> </td></tr><tr><td>개인정보 보호담당자</td><td> </td><td> 선택 ▾ - - - </td><td> </td></tr></table>				성명	연락처(HP)	이메일	개인정보 보호책임자		선택 ▾ - - -		개인정보 보호담당자		선택 ▾ - - -	
	성명	연락처(HP)	이메일												
개인정보 보호책임자		선택 ▾ - - -													
개인정보 보호담당자		선택 ▾ - - -													

신고 접수하기

〈그림 2-6〉 홈페이지 신고 양식

다. 침해사고에 대한 수사 의뢰

해킹, 인터넷을 이용한 사기, 주민등록번호의 도용 등 침해 행위에 대하여 침해 행위자에 대한 수사 등 법적인 처리를 고려하는 경우에는 경찰청 사이버안전국에 신고하여 지원을 받을 수 있다.

- 경찰청 사이버안전국 : <http://www.ctrc.go.kr>, ☎ (국번없이) 182



〈그림 2-7〉 경찰청 사이버안전국 침해사고 신고

민간부분 침해사고 대응안내서



03

제3장 침해사고 조치 가이드

1. 침해사고 유형	24
2. 침해사고 점검항목 및 조치방안 (개인)	26
3. 침해사고 점검항목 및 조치방안 (기업)	28
4. 시스템 유형별 보안 조치 방안	33



제3장 침해사고 조치 가이드

1. 침해사고 유형

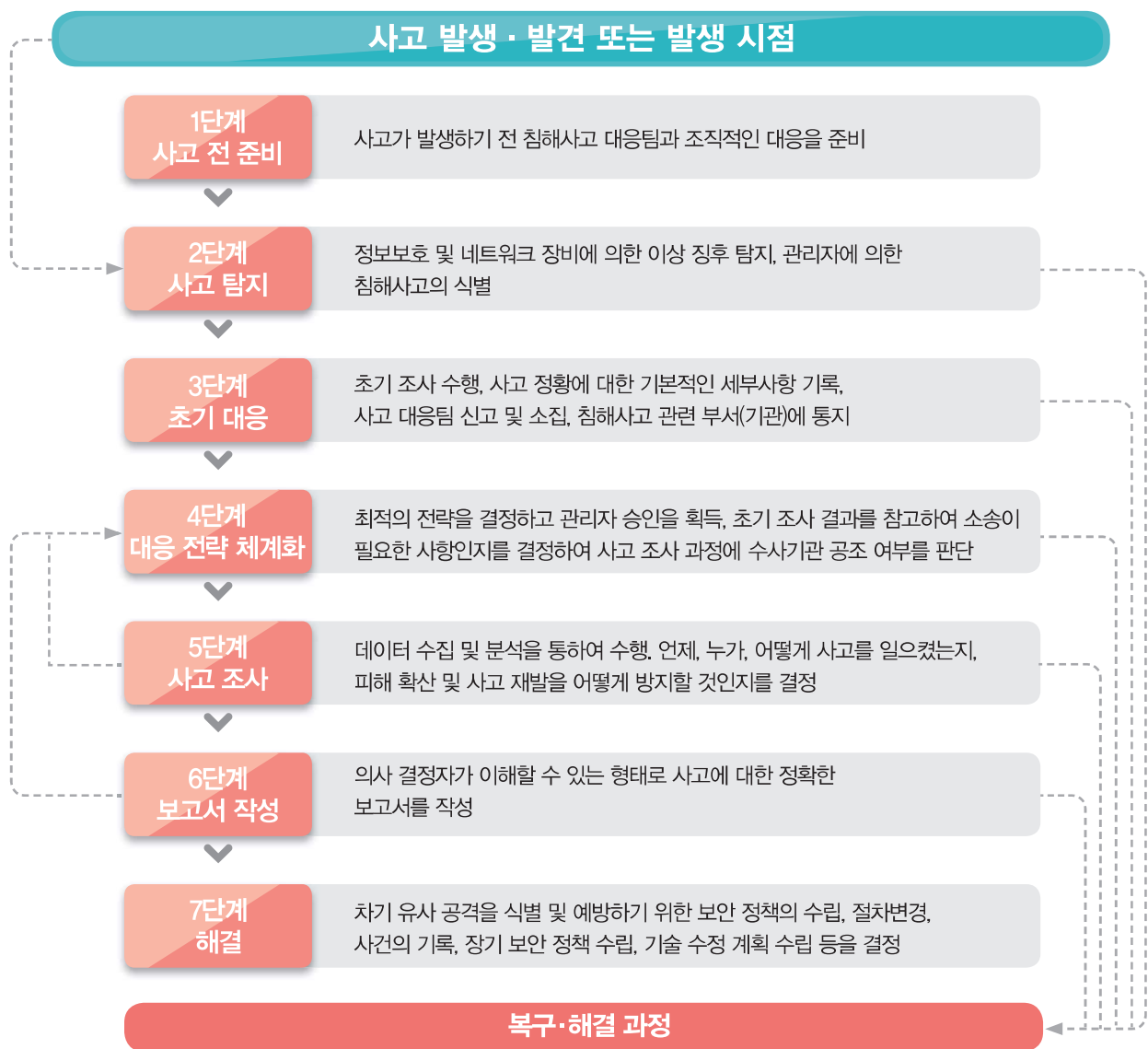
침해사고 정의

정보통신망 이용촉진 및 정보보호 등에 관한 법률 제2조 1항 7호

'침해사고'란 해킹, 컴퓨터바이러스, 논리폭탄, 메일폭탄, 서비스 거부 또는 고출력 전자기파 등의 방법으로 정보통신망 또는 이와 관련된 정보시스템을 공격하는 행위를 하여 발생한 사태를 말한다.



침해사고 대응 7단계



특히, 침해사고가 발생하거나 인지한 경우, 정보통신망법에 의거하여 그 사실을 즉시 미래창조과학부나 한국인터넷진흥원에 신고하여야 한다. 신고 대상 및 절차 등 세부 내용은 '제2장 사이버 침해사고 신고' 부분을 참고하도록 한다.

나. 조치방안

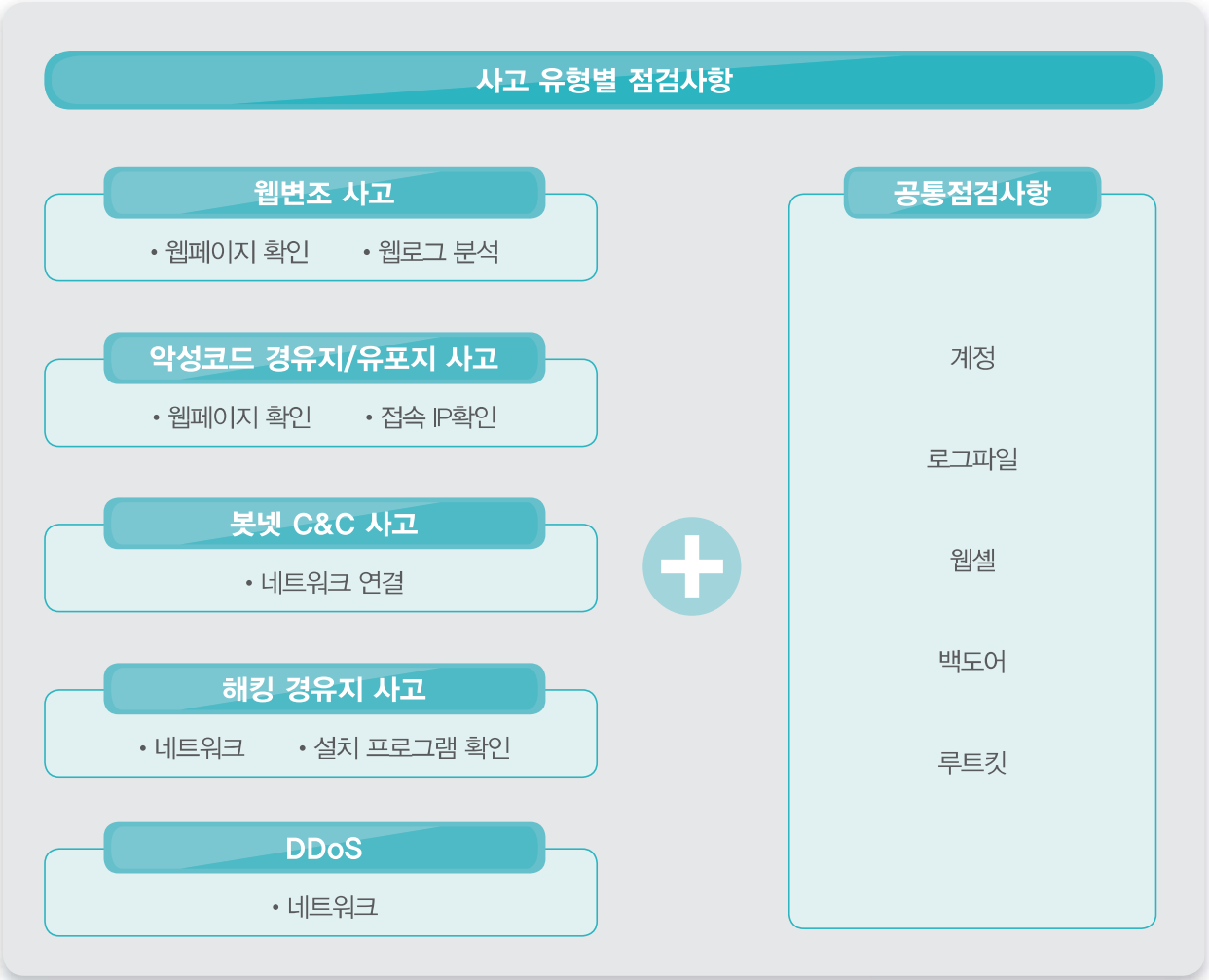
- 정품 소프트웨어 사용
 - 신뢰할 수 없는 경로에서 획득한 운영체제, 유틸리티, 정품 소프트웨어 인증우회 프로그램 등을 설치하지 않는다.
- 운영체제 및 기타 소프트웨어에 대한 최신 패치 적용
 - 운영체제 및 기타 소프트웨어 대한 자동 보안패치 기능을 사용한다.
 - 자동 보안패치를 지원하지 않는 소프트웨어의 경우, 주기적으로 최신 버전을 확인하여 수동패치를 수행한다.
- 백신 소프트웨어 설치
 - 한 개 이상의 백신 소프트웨어를 설치하여 실시간 감시 수행 및 정기적인 전체 검사를 수행한다.
- 신뢰할 수 있는 페이지 방문
 - 공격자는 취약점을 공격하는 코드를 사용하여 웹 페이지 단순방문 만으로도 악성코드를 감염시킬 수 있으므로 신뢰할 수 없는 웹페이지 접속 자제, 파일 다운로드 및 실행을 하지 않는다.
 - 신뢰할 수 없는 발송자가 전송한 이메일은 열람하지 않는다.
- 중요 데이터 백업 수행
 - 랜섬웨어 등과 같은 자료 파괴형 악성코드 피해를 대비하기 위해, 중요 데이터의 경우 주기적으로 PC와 분리된 별도의 저장매체(외장하드 등)또는 클라우드 서비스를 통해 데이터 백업을 수행한다.
- 인터넷 공유기 관리자 기본 패스워드 변경 및 Wi-Fi 비밀번호 설정
 - 인터넷 공유기의 관리자 기본 패스워드를 변경하지 않을 경우, 공격자는 동일한 기본 패스워드를 사용하여 인터넷 공유기를 해킹할 수 있으므로 관리자 및 Wi-Fi 비밀번호 변경을 수행한다.
 - 공격자는 취약점을 악용하여 인터넷 공유기 해킹이 가능하므로, 최신 펌웨어 패치를 수행한다.
- 회원가입 사이트마다 별개 아이디 · 패스워드 사용
 - 아이디, 패스워드를 여러 홈페이지 대상으로 동일하게 사용하게 되면 계정 정보가 유출될 경우, 피해가 확산될 수 있으므로 사용하는 홈페이지마다 별개의 인증정보를 설정하여 사용한다.

3. 침해사고 점검항목 및 조치방안(기업)

한국인터넷진흥원에 분석을 요청할 경우 유의사항

- 침해사고 관련 파일(악성코드, 프로세스)등을 제거하지 않은 상태에서 분석요청
- 불가피하게 제거해야 할 경우 악성파일은 경로와 MAC time(생성 · 접근 · 수정 시간)을 확보하고, 프로세스는 해당 프로세스와 관련된 디렉토리 또는 파일 경로와 MAC time을 확보해야 함(악성파일 백업 필수)

※ 리눅스의 경우 stat 명령문과 lsot명령문 활용



사고 유형 >> 공통

점검내용

계정

- 사용하지 않는 계정 및 숨겨진 계정 확인
 - ▶ Window : [관리도구] → [컴퓨터 관리] → [로컬사용자 및 그룹] → [사용자] 정보 확인
 - ▶ Linux : /etc/passwd 확인
- \$ 문자가 포함된 계정 확인 • 패스워드 미설정 계정 확인
- /bin/bash 점검

로그파일

- 이벤트로그 및 시스템 로그 변조 유무 확인
 - ▶ Window : [관리도구] → [컴퓨터 관리] → [이벤트뷰어] 확인
 - ▶ Linux : /var/log/secure, message 등 확인
- 웹로그 경로 및 변조 유무 확인
 - ▶ [관리도구] > 인터넷정보서비스(ICS)에서 관리에서
- 웹로그 경로 확인 ▶ Linux : /usr/local/apache/logs 확인
- 웹로그생성/수정 시간 확인

웹셀

- 확장자별 웹셀 Signature 점검
 - ▶ asp, aspc, asa, cer, cdx, php, jsp, html, htm, jpg, jpeg, gif, bmp, png
- 휘슬(WHISTL)사용
 - ※ www.boho.or.kr 신청 ※ 사용법 : 부록2 참조

백도어

- 네트워크 상태확인 ▶ map-sw 서버IP (원격에서 실행해야 됨)
- 비정상 포트 및 외부연결 확인
 - ▶ Window : netstat, TCPView 등 사용
 - ▶ Linux : netstat -nlp, lsof -i
- 6666, 6667 등 의심 Port 확인의심 Port를 사용하는 프로세스 확인

루트킷

- 숨겨진 프로세스 및 비정상 프로세스 확인
- 변조된 파일 및 시스템 명령어 확인
 - ▶ Window : IceSword, GMER 등 사용
 - ▶ Linux : Rootkit Hunter, Check Rootkit 등 사용
- Rootkit Hunter 업데이트 필수 ▶ rktunter- update
 - ※ 사용법 : 부록2 참조

조치사항

- 사용하지 않는 계정과 숨겨진 계정 삭제

- 웹셀 발견시 업로드 된 경로를 파악하여 해당 취약점 제거

- 백도어 포트가 발견될 경우 해당 port에 대한 차단정책을 적용하고 백도어 서비스와 관련된 파일을 확인하여 삭제(차단 정책 적용을 위해 서버내 방화벽 (iptables, hosts,allom/deny 활용 가능)

- 루트킷의 경우 일부 시스템 명령어만 변조된 경우는 무결성이 보장된 명령어로 교체 가능하나 다수의 라이브러리들이 변조되었을 경우는 시스템 재설치 필요

사고 유형 >> 웹변조

점검내용

웹페이지 확인

- 공통 : index.html, main.html, default.html, index.pho, main.pho
- Window : index, asp, main, asp, default, asp
-
- 기타 메인페이지로 설정된 파일 확인

HTTP 메소드

- Window : WebDAV 활성화 확인
 - ▶ [관리도구] → [인터넷정보서비스(IS)관리] → [웹서비스 확장] 허용 여부 확인
- Linux : Apache 웹서버의 httpd.conf확인
- 웹로그 경로 및 변조 유무 확인
 - ▶ <Directory>에서 MOME 또는 PUT 메소드 allow 설정 여부 확인
-
- Window : [사용금지]로 설정 • Linux : deny로 설정

웹로그 분석

- MOME, PUT 메소드 공격 여부 확인
 - ▶ grep MOME 웹로그 : grep -v 404
-
- Linux : grep 기본 제공 • Window : grep.exe 사용

조치사항

- 웹페이지 내용이 변경되었을 경우 휘슬을 통해 웹셀 감염여부를 확인하고 발견될 경우 삭제 조치
- 리눅스 아파치 웹서버의 설정 파일에서 사용하지 않는 HTTP 메소드에 대해 허용 금지
- IS 웹서버 또는 아파치 웹서버의 설정이 변경되었을 경우 관리자 계정 변경 필수
- 웹셀이 발견될 경우 웹 접속로그를 통해 웹셀에 접근한 IP를 확인하고 방화벽을 통해 접근 제한 정책 적용

사고 유형 >> 악성코드 경유지 / 유포지

점검내용

웹페이지 확인

- 악성코드 유포 페이지 확인 ▶x.html 등과 같은 의심페이지 점검
- 악성코드 유포 URL삽입 페이지 검출
 - ▶ grep -r "유포지 URL" 웹페이지 Path
- 웹페이지 생성 및 수정 시간 확인
-
- KISA에서 보급중인 휘슬 설치 권장
 - ※ krcert.or.kr 또는 boho.or.kr 신청

접속 IP 확인

- 악성코드 유포/경유 페이지 접속 IP 추출
 - ▶grep "유포/경유 페이지 Path" 웹로그 Path
 - ※ 추출된 IP는 악성코드에 감염된 좀비 PC를 확보하는게 매우 중요

조치사항

- 악성코드 유포 페이지에 대한 파일 생성 및 수정시간 확인
- 유포 페이지 생성 시점 기준으로 웹 접속로그 및 시스템 로그를 분석하여 또 다른 침해 여부 확인
- 휘슬을 통해 웹셀 감염 여부를 확인하고 발견될 경우 삭제 조치
- 웹셀이 발견될 경우 웹접속로그를 통해 웹셀에 접근한 IP를 확인하고 방화벽을 통해 접근 제한 정책 적용

사고 유형 >> 봇넷 C&C

점검내용

네트워크 연결

- 외부 네트워크 연결 확인
 - ▶ Windows : - netstat -na를 통해 확인 후 의심 Port (6667, 6668 등과 같은 IRC Port)에 연결된 IP를 확인
 - ▶ Linux : - netstat -na 또는 ss -t -n - Window와 동일하게 확인
- 네트워크 트래픽 분석
 - ▶ Windows : Wireshark를 사용하여 패킷 분석
 - ▶ Linux : TCPDUMP를 사용하여 패킷 분석



조치사항

- 외부 네트워크와 연결된 백도어 포트 발견시 방화벽을 통해 해당 포트로의 접근 제한 정책 적용
- 백도어 포트 서비스를 실행중인 파일 확인 및 삭제

사고 유형 >> 해킹 경유지

점검내용

네트워크

- 공통 : Nmap, netstat 사용하여 의심 Port 확인
 - ▶ nmap -sV 서버IP ▶ 1723, 4444, 38317 등 의심 Port 확인
- Windows : RRAS 서비스 설정 확인
 - ▶ [컴퓨터 관리] → [서비스 및 응용프로그램] → [서비스]의 Routing and Remote Access 서비스 시작 유형(사용안함) 확인
- Linux : PPTP 서비스 실행 확인
 - ▶ ps -ef 명령 실행 후 pptpd 프로세스 확인
 - ※ RRAS 및 PPTP 프로세스는 VPN 서비스

네트워크

- Windows : CCProxy, RealVNC 등 설치 확인
 - ▶ [제어판] → [프로그램 추가/제거] 에서 설치 여부 확인
 - Linux : Rootkit Hunter, Check Rootkit 검사를 통해 악성 프로그램 설치 여부 확인
-
- Rootkit Hunter 업데이트 필수 ▶ rktunter -update
 - ※ 사용법 : 부록2 참조



조치사항

- 윈도우 서버의 RRAS서비스가 실행중일 경우 해당 서비스 중지
- 윈도우 서버의 이벤트 로그를 통해 RRAS서비스를 실행시킨 이력 및 IP를 확인하고 해당 IP에 대한 접근 제한 정책 적용
- 리눅스 서버의 PPTP 서비스가 실행중일 경우 해당 프로세스 중지
- 리눅스 서버의 시스템 로그를 통해 PPTP 서비스를 실행시킨 이력 및 IP를 확인하고 해당 IP에 대한 접근 제한 정책 적용

사고 유형 >> DDoS

점검내용

네트워크 연결

- 홈페이지 접속 상태 및 응답 지연시간 확인
 - ▶ ping "홈페이지주소"
- 시스템에 접속한 IP를 확인하여 트래픽 이상 징후 확인
 - ▶ Windows : netstat -na
 - ▶ Linux : netstat -na 또는 ss -t
- 네트워크 트래픽 분석
 - ▶ Window : Wireshark를 사용하여 패킷 분석
 - ▶ Linux : TCPDump를 사용하여 패킷 분석



조치사항

- KISA 사이버 대피소 또는 ISP에서 운영중인 DDoS 방어서비스 적용 신청
- 보안장비를 통해 DDoS를 유발하는 IP에 대한 접근차단
 - ※ ISP를 통해 공격 로그 제공 요청

4. 시스템 유형별 보안 조치방안

가. 웹 서버 취약점 조치 방안

상세한 조치방안은 웹서버 구축 보안점검 안내서 참고

자료실	정부3.0 정보공개	주요사업	고객광장	알림마당	자료실	진흥원소개
자료실 관련법령·기술안내서 • 법령현황 • 고시·권고 • 기술안내서 가이드 기관내규(사규) 사규 제·개정예고 KISA Library	• 사전정보공표 • 정보공개 • 경영공시 • 자체경영공시 • 사업실명제 • 참여알리미 서비스	• 해외진출 및 국제협력 • 정책연구 • 인터넷 진흥 • 인터넷 주소관리 • 개인정보보호 • 사이버보안인재센터 • 사이버 침해대응	• 고객원장 • 청렴윤리 • 내부감사결과 • 고객만족경영 • 지속가능경영보고서 • ARS 서비스 안내 • 개인정보처리방침	• 공지사항 • 보도자료 • 사회공헌 • 포토뉴스 • 기고·인터뷰 • 채용정보 • 입찰공고 • 위탁과제 • 알림판	• 관련법령·기술안내서 • 기관내규(사규) • 사규 제·개정예고 • KISA Library	• 기관장 인사말 • 연혁 • 조직도 • CI • 비전 및 목표 • 찾아오시는길

무선랜 보안 안내서	일반	중급
웹서버구축 보안점검 안내서		
웹어플리케이션 보안 안내서	IT시스템관리자	고급
홈페이지 개발보안 안내서		

<http://www.kisa.or.kr> 자료실 ▶ 관련법령·기술안내서 ▶ 기술안내서 가이드 ▶ 웹서버 구축 보안점검 안내서

- OS에 대한 최신 패치 적용
 - OS 제조사 홈페이지나 보안 취약점 정보 사이트를 주기적으로 방문하여 현재 사용하고 있는 OS에 대한 최신 취약점 정보획득 및 패치
 - 정기적으로 취약점 점검 도구와 보안 체크리스트를 사용하여 OS의 보안 취약점 점검
- 웹 서버 전용 호스트로 구성
 - 웹 서비스 운영에 필요한 최소한의 프로그램들만 남겨두고 불필요한 서비스들은 반드시 제거
 - 시스템 사용을 목적으로 하는 일반 사용자 계정은 모두 삭제하거나 최소한의 권한만 할당
 - 오직 관리자만이 로그인 가능하도록 설정
- 서버에 대한 접근 제어
 - 관리목적의 웹 서버 접근은 콘솔 접근만을 허용
 - 위 사항이 불가능할 경우 관리자가 사용하는 PC의 IP만 접근이 가능하도록 접근제어 수행
- DMZ 영역에 위치
 - 웹 서버를 방화벽에 의해서 보호 받도록 하고, 웹 서버가 침해당하더라도 웹 서버를 경유해서 내부 네트워크로의 침입은 불가능하도록 구성

- 강력한 관리자 계정 패스워드 사용
 - 관리자 계정 패스워드는 유추가 불가능하고 패스워드 크랙으로도 쉽게 알아낼 수 없는 강력한 패스워드 사용
 - 패스워드 길이는 최소 8자 이상 (대문자, 소문자, 숫자, 기호 등 2종류 이상으로 구성 시 10자리 이상, 3종류 이상으로 구성 시 8자리 이상)
 - 사전에 없는 단어를 사용하고 기호를 최소 한 개 이상 포함
- 파일 접근권한 설정
 - 관리자 계정이 아닌 일반 사용자 계정으로 관리자 계정이 사용하는 파일들을 변경할 수 없도록 구성
- 웹 프로세스의 권한 제한
 - 시스템 전체적인 관점에서 웹 프로세스가 웹 서비스 운영에 필요한 최소한의 권한만을 갖도록 제한
 - 웹 서버 관리시에는 일반적으로 사용되는 nobody 권한으로 웹 프로세스가 동작하도록 구성
- 로그 파일의 보호
 - 침입 혹은 침입 시도 등 보안 문제점 파악을 위해 로그 파일이 노출, 변조 혹은 삭제되지 않도록 불필요한 접근으로부터 보호
 - 불필요한 접근으로부터 보호하기 위해 로그파일을 별도의 서버에 백업하여 관리하는 것이 필요
 - 로그파일은 최소 6개월 이상의 로그를 확보하는 것이 필요
- 웹 서비스 영역의 분리
 - 웹 서비스 영역과 시스템(OS)영역을 분리시켜서 웹 서비스의 침해가 시스템 영역으로 확장될 가능성을 최소화
 - 웹 서버의 루트 디렉토리와 OS의 루트 디렉토리를 다르게 지정
- 설정파일 백업
 - 초기 설정 파일을 백업 받아서 보관해 두고, 변경이 있을 때마다 설정 파일을 백업하여 해킹사고 발생 시 빠르게 복구
- Inbound 트래픽 제한
 - 공개용 침입차단시스템을 이용하여 트래픽을 제한
 - ※ 리눅스 커널에서는 iptables 또는 ipchains 침입차단 시스템이 기본으로 제공됨
 - 전체 서비스(포트)에 대해 차단 설정 후 고객이 필요로 하는 서비스(포트)에 대해 선별적으로 접속 제한을 해제
 - ※ 필요 서비스(포트) 예 : FTP(21), SSH(22), SMTP(25), DNS(53), SSL(443)등
 - 필요할 경우 아래와 같이 iptables를 사용하여 특정 포트에 대한 Inbound 트래픽을 제한
 - ※ iptables는 테이블 형식으로 관리되며, 먼저 등록된 것이 효력을 발생하기 때문에 허용하는 정책이 거부하는 정책보다 먼저 위치해야 함

```
• iptables -A INPUT -p TCP --dport 22 -s ip앞 세자리.0/24 -j ACCEPT
• iptables -A INPUT -p TCP --dport 22 -s 192.168.0.0/24 -j ACCEPT
• iptables -A INPUT -p TCP --dport 22 -j DROP
→ ssh 포트에 대해 특정 ip군과 사설ip만 허용하고 나머지는 Drop
```

나. 네트워크 취약점 조치 방안

상세한 조치 방안은 웹서버 구축 보안점검 안내서 참고

자료실

- 사전정보공표
- 정보공개
- 경영공시
- 자체경영공시
- 사업실명제
- 참여알리미 서비스
- 해외진출 및 국제협력
- 정책연구
- 인터넷 진흥
- 인터넷 주소관리
- 개인정보보호
- 사이버보안인재센터
- 사이버 침해대응
- 고객원장
- 청렴윤리
- 내부감사결과
- 고객만족경영
- 지속가능경영보고서
- ARS 서비스 안내
- 개인정보처리방침
- 공지사항
- 보도자료
- 사회공헌
- 포토뉴스
- 기고·인터뷰
- 채용정보
- 입찰공고
- 위탁과제
- 알림판
- 관련법령·기술안내서
- 기관내규(사규)
- 사규 제·개정예고
- KISA Library
- 기관장 인사말
- 연혁
- 조직도
- CI
- 비전 및 목표
- 찾아오시는길

무선랜 보안 안내서	일반	중급
웹서버구축 보안점검 안내서		
웹어플리케이션 보안 안내서	IT시스템관리자	고급
홈페이지 개발보안 안내서		

<http://www.kisa.or.kr> 자료실 ▶ 관련법령·기술안내서 ▶ 기술안내서 가이드 ▶ 웹서버 구축 보안점검 안내서

- 네트워크 장비의 원격 접근 제한 설정
 - 허용된 ip 외에는 telnet이나 ssh를 통해 네트워크 장비에 원격 접속할 수 없도록 제한
- SNMP 접근 제한 설정
 - 패스워드 역할을 하는 community 문자열의 default 값(public)을 추측하기 어렵고 의미 없는 문자열로 변경
 - 네트워크 장비에서 ACL(access-list) 기능을 이용하여 SNMP에 대한 접근 제한
- 불필요한 서비스 중단
 - 네트워크 장비를 처음 설치하거나 네트워크 장비의 OS등을 업그레이드 한 후에는 사용하지 않거나 보안상 불필요한 서비스를 반드시 중지
- 설정을 통한 로그인시간 제한
 - 로그인 한 후 일정 시간 동안 아무런 명령어를 입력하지 않으면 자동으로 접속을 종료하도록 설정
- 로그 관리
 - 시스템 자체적으로 access-list와 같은 특정한 룰에 매칭되는 로그를 남기도록 설정
- 보안 패치 적용
 - 네트워크 보안 취약점 정보 사이트를 주기적으로 방문하여 최신 패치 적용

다. DB 취약점 조치방안

상세한 조치 방안은 웹서버 구축 보안점검 안내서 참고

KISA한국인터넷진흥원

정부3.0정보공개

주요사업

고객광장

알림마당

자료실

진흥원소개

자료실

관련법령·기술안내서

법령현황

고시·권고

기술안내서 가이드

기관내규(사규)

사규 제·개정예고

KISA Library

사전정보공표

정보공개

경영공시

자체경영공시

사업실명제

참여알리미 서비스

해외진출 및 국제협력

정책연구

인터넷 진흥

인터넷 주소관리

개인정보보호

사이버보안인재센터

사이버 침해대응

고객현황

청렴윤리

내부감사결과

고객만족경영

지속가능경영보고서

ARS 서비스 안내

개인정보처리방침

공지사항

보도자료

사회공헌

포토뉴스

기고·인터뷰

채용정보

입찰공고

위탁과제

알림판

관련법령·기술안내서

기관내규(사규)

사규 제·개정예고

KISA Library

기관장 인사말

연혁

조직도

CI

비전 및 목표

찾아오시는길

무선랜 보안 안내서

일반

중금

웹서버구축 보안점검 안내서

IT시스템관리자

고금

웹어플리케이션 보안 안내서

홈페이지 개발보안 안내서

<http://www.kisa.or.kr> 자료실 ▶ 관련법령 · 기술안내서 ▶ 기술안내서 가이드 ▶ 웹서버 구축 보안점검 안내서

DB 구분 >> My SQL

- DB 시스템 보안패치 적용
 - My-SQL이 동작하는 시스템에 대한 기본적인 보안패치 적용
- DBMS 계정 확인
 - My-SQL 다폴트 설치 시 설정되지 않은 채 비어있는 데이터베이스 관리자 패스워드 변경
 - ※ My-SQL의 관리자인 root는 기본 설치 시 비밀번호가 NULL로 설정됨
 - My-SQL 설치 시 기본적으로 생성되어 있는 'test' 계정 삭제
- 원격으로부터의 접속 차단
 - My-SQL이 다폴트로 리스닝하는 3306/tcp 포트를 차단함으로써 데이터베이스가 인가된 어플리케이션에 의해서만 사용되도록 설정
- 데이터베이스내의 사용자별 접속/권한 설정 확인
 - DB 생성 후 사용자 접근 권한 설정 시 일반 사용자에게는 최소한의 권한만을 부여
- 데이터 디렉토리 보호
 - My-SQL 데몬을 mysql이라는 시스템 계정으로 구동할 경우, mysql 디렉토리 이하에 대한 읽기, 쓰기 권한을 제한함으로써 데이터 파일 및 로그파일 보호

DB 구분 >> MS SQL

- DB 시스템 보안패치 적용
 - MS에서 제공되는 서비스 팩과 수시로 발표되는 보안패치 설치
- 인증 및 계정관리 확인
 - 윈도우 인증모드 사용을 통해, SQL 사용 권한이 없는 도메인 사용자 또는 윈도우 사용자로부터 윈도우 비밀번호 정책을 사용하여 보안 강화
 - 게스트 계정 비활성화
 - sysadmin은 데이터베이스에 대한 완전한 관리 권한을 필요로 하는 사용자를 위해 만들어진 역할이므로, 이 역할에 인증되지 않은 사용자는 삭제
- 외부로부터의 SQL Server 포트 접속 차단
 - SQL Server의 디폴트 포트인 1433/tcp, 1434/tcp를 임의의 다른 포트로 설정하여 운영하고, 인가된 시스템에서만 접근이 가능하도록 설정
- 확장 프로시저 제거
 - 서버의 유지관리를 위해 제공하는 확장 프로시저 중 공격에 자주 이용되고 있는 특정 프로시저(xp_cmdshell) 제거 되도록 설정
 - 데이터 백업 등의 이유로 데이터베이스로 원격에서 접속해야 하는 경우 SSH 프로토콜 사용

라. 어플리케이션 취약점 조치 방안

상세한 조치 방안은 웹서버 구축 보안점검 안내서 참고

KISA

인국인터넷진흥원

정부

정보공개

주요사업

고객광장

알림마당

자료실

진흥원소개

자료실

관련법령·기술안내서

법령현황

고시·권고

기술안내서 가이드

기관내규(사규)

사규 제·개정예고

KISA Library

· 사전정보공표

· 정보공개

· 경영공시

· 자체경영공시

· 사업실명제

· 참여알리미 서비스

· 해외진출 및 국제협력

· 정책연구

· 인터넷 진흥

· 인터넷 주소관리

· 개인정보보호

· 사이버보안인재센터

· 사이버 침해대응

· 고객현장

· 청렴윤리

· 내부감사결과

· 고객만족경영

· 지속가능경영보고서

· ARS 서비스 안내

· 개인정보처리방침

· 공지사향

· 보도자료

· 사회공헌

· 포트뉴스

· 기고·인터뷰

· 채용정보

· 입찰공고

· 위탁과제

· 알림판

· 관련법령·기술안내서

· 기관내규(사규)

· 사규 제·개정예고

· KISA Library

· 기관장 인사말

· 연혁

· 조직도

· CI

· 비전 및 목표

· 찾아오시는길

무선랜 보안 안내서

웹서버구축 보안점검 안내서

웹어플리케이션 보안 안내서

홈페이지 개발보안 안내서

일반

IT시스템관리자

중급

고급

http://www.kisa.or.kr

자료실

▶ 관련법령 · 기술안내서

▶ 기술안내서 가이드

▶ 웹서버 구축 보안점검 안내서

- 웹 취약점 점검 서비스 수행(<http://www.boho.or.kr>)
 - 원격으로 웹 공격에 대한 취약점 점검 수행, 점검 결과 제공

KISA

보호나라 & KrCERT

인터넷침해사고 정보단계

2016.12.02, 10:59

관심

사이버위협

보안서비스

다운로드

상담 및 신고

자료실

랜섬웨어

KrCERT/CC

경보단계

스마싱

무선랜 보안

인터넷 공유기

웹 취약점 점검

사이버대피소

PC원격점검

DNS 싱크홀

맞춤형 전용백신

취소 / 캐슬

해킹 사고

피싱 사고

웹/바이러스 사고

S/W 신규 취약점

해킹/바이러스 상담

발신번호가장표시

보안공지

보고서

가이드 및 매뉴얼

최신동향

참고 사이트

공지사항

경의 및 감염경로

예방수칙

복구방법

동향

Welcome Message

Vision & Mission

Contact

Security Advisory

- 휘슬 설치 및 주기적인 검사 수행(<http://www.boho.or.kr>)
 - 공격자에 의해 생성된 웹쉘 및 악성코드 은닉 사이트 탐지 가능

휘슬(WHISTL)

[홈](#) > [다운로드](#) > [휘슬 / 캐슬](#) > [휘슬\(WHISTL\)](#)

▣ 휘슬이란?

웹 서버 해킹에 사용되는 웹쉘 파일 및 악성코드 은닉 사이트를 서버 관리자들이 쉽게 탐지 할 수 있도록 하는 프로그램입니다.
 휘슬은 홈페이지의 보안 강화용이 아닙니다. 해킹을 예방하기 위해서는 전용 보안장비를 운영하시고 취약점 점검을 수행하시기 바랍니다.

▣ 이용대상

본 프로그램은 '중소기업기본법 제2조'에 해당하는 중소기업에 제공됩니다.

▣ 신청방법

- 신청서를 다운로드하여 작성하신 후 이메일에 첨부하여 신청하시기 바랍니다.
- 프로그램은 신청서에 작성하신 전자우편으로 보내드리며, 신청하신 날짜로부터 2~3일 정도 소요될 수 있습니다.



Whisl 신청서 (한글 hwp)
 DOWNLOAD



Whisl 신청서 (MS Word)
 DOWNLOAD

▣ 문의 및 기술 지원

- 이메일 : whisl2010@krcert.or.kr

- 캐슬 설치 및 운영(<http://www.boho.or.kr>)
 - 홈페이지 보안성 강화를 위한 웹방화벽 기능 제공

캐슬(CASTLE)

[홈](#) > [다운로드](#) > [휘슬 / 캐슬](#) > [캐슬\(CASTLE\)](#)

▣ 캐슬이란?

웹 취약점을 악용한 공격을 사전 차단할 수 있는 웹 방화벽 프로그램입니다.
 주요 취약점을 공격하는 침입 시도 및 공격코드들을 차단할 수 있으며 관리 기능으로 손쉽게 정책이나, 설정을 수정할 수 있습니다.
 이전 버전(PHP 1.0.1, JSP 1.0.1, ASP 1.0.0) 사용자 분들께는 새롭게 다운로드 하여 업데이트 하시기 바랍니다.

▣ 이용대상

본 프로그램은 '중소기업기본법 제2조'에 해당하는 중소기업에 제공됩니다.

▣ 신청방법

- 다운로드 버튼을 클릭하여 정보 입력 후 신청하시기 바랍니다.
- 입력하신 메일 주소로 캐슬 프로그램, 사용자 매뉴얼, 사용권 계약서를 보내 드립니다.



CASTL(ASP, PHP, JSP) 및 사용설명서
 DOWNLOAD

▣ 문의 및 기술 지원

- 이메일 : castle@krcert.or.kr

• 접근통제 취약점에 대한 조치

설명 - /admin, /admin_login 등과 같이 보편적으로 사용되는 관리자 페이지 주소를 입력하여 해당페이지로 접근이 가능한 취약점

- 관리자 페이지를 유추하기 어려운 주소로 변경하고 관리자 호스트 IP만 접근 가능하도록 설정

• 부적절한 파라미터 취약점에 대한 조치

설명 - URL, 쿼리 문자열, HTTP 헤더, 쿠키, HTML 폼 인자, HTML hidden 필드 등의 HTTP 요청을 변조하여 웹사이트의 보안 메커니즘을 우회하는 취약점

- 모든 입력 값에 대해 중앙에서 집중적으로 처리하는 하나의 컴포넌트나 라이브러리를 사용하여 모든 인자에 대해 사용 전에 입력 값검증을 수행하도록 구성
- 파일 다운로드 시 파일명을 직접 URL에서 사용하거나 입력받지 않도록 하며 게시판 이름과 게시물 번호를 이용하여 서버 측에서 데이터베이스 재검색을 통하여 해당 파일을 다운로드 할 수 있도록 수정
- 다운로드 위치는 지정된 데이터 저장소를 지정하여 사용하고, 데이터 저장소 상위 디렉토리로 이동되지 않도록 설정

• Cookie Injection 취약점에 대한 조치

설명 - 쿠키 값 변조를 통해 다른 사용자로의 위장 및 권한상승을 수행할 수 있는 취약점

- Client Side Session 방식인 Cookie는 구조상 다양한 취약점에 노출될 수 있으므로 웹서버에서 제공되는 Server Side Session을 사용
- SSL과 같은 기술을 사용하여 로그인 트랜잭션 전체를 암호화

• SQL Injection(악의적인 명령어 주입) 취약점에 대한 조치

설명 – 데이터베이스 접근을 위해 사용되는 SQL Query문을 비정상적으로 조작하여 사용자 인증 우회, DB에 저장된 데이터 열람, DB의 시스템 명령어를 이용하여 시스템 조작 등의 행위를 할 수 있는 취약점

- 데이터베이스와 연동하는 스크립트의 모든 파라미터를 점검하여 사용자의 입력 값이 SQL injection을 일으키지 않도록 수정
 - ※ 사용자 입력값 및 URL 인자값에 대해 특수문자(' , ' , ; , % , Space, — , + , < , > , (,) , # , & 등)와 SQL 구문 (Insert, Select 등)이 포함되어 있는지 검사 후 허용되지 않은 문자열이나 문자가 포함된 경우에는 예외로 처리
- SQL 서버의 에러 메시지를 사용자에게 보여주지 않도록 설정
- 웹 어플리케이션이 사용하는 데이터베이스 사용자의 권한을 제한하여 일반 사용자 권한으로는 모든 system stored procedures에 접근하지 못하도록 설정함으로써 SQL Injection 취약점을 이용하여 데이터베이스 전체에 대한 제어권을 얻거나 데이터베이스를 운용중인 서버에 접근이 불가능하도록 수정
- php.ini 설정 중 magic_quotes_gpc 값을 On으로 설정
- Upload 파일을 위한 전용 디렉토리를 별도 생성하여 httpd.conf와 같은 웹 서버 데몬 설정파일에서 실행 설정을 제거함으로써, Server Side Script가 Upload되더라도 웹 엔진이 실행하지 않게 환경을 설정
 - ※ IS보안 설정
 - 설정 → 제어판 → 관리도구 → 인터넷 서비스 관리자 선택 → 해당 Upload 폴더에 오른쪽 클릭을 하고 등록 정보 → 디렉토리 → 실행권한을 '없음'으로 설정
 - ※ Apache 설정
 - Apache 설정 파일인 httpd.conf의 해당 디렉토리에 대한 문서 타입을 컨트롤하기 위해 Directory 세션의 AllowOverride 지시자에서 FileInfo 또는 All 추가

```
<Directory "/usr/local/apache">
AllowOverride FileInfo(또는 All)
</Directory>
```

- 파일 업로드 디렉토리에 .htaccess 파일을 만들고 AddType 지시자를 이용, 현재 서버에서 운영되는 Server Side Script 확장자를 text/html로 MIME Type을 재조정하여 업로드 된 Server Side Script가 실행되지 않도록 설정

```
<.htaccess>
<FilesMatch ".*(ph|inc|lib)">
Order allow, deny
Deny from all
</FilesMatch>
AddType text/html .html .htm .php .php3 .php4 .phtml .phps .in .cgi .pl .shtml .jsp
```

- 설정 후 데몬 재시작
 - ※ 모든 확장자를 제한하고 허용하는 일부 확장자만 업로드 되도록 제한 확장자 검사 우회 (ex. shell.gif.jsp, shell.jpg.jsp)를 막기 위해 뒤에서부터 검사하도록 수정

• XSS(크로스사이트 스크립팅) 취약점에 대한 조치

설명 – 자바스크립트처럼 클라이언트 측에서 실행되는 언어로 작성된 악성 스크립트 코드를 웹 페이지, 웹 게시판 또는 이메일에 포함시켜 사용자에게 전달하면, 해당 웹 페이지나 이메일을 사용자가 클릭하거나 읽을 경우 악성 스크립트 코드가 웹 브라우저에서 실행되는 취약점

- 사용자로부터 입력받는 모든 값을 서버에서 검증 후 입력 받도록 수정
- 스크립트 문장에 존재할 수 있는 아래와 같은 특수 문자를 다른 문자로 변환하도록 소스를 수정
 - ※ 특수 문자 치환 예
 - < → <
 - > → >
 - (→ (
 -) →)
 - # → #
 - & → &
- 특수 문자 변환을 위해서는 Server Side 언어별로 아래와 같은 함수 이용 가능
 - ※ ASP : Server,HTMLEncode()
 - PHP : htmlspecialchars() 또는 strip_tags() 또는 strip_replace()

• 버퍼 오버플로우 취약점에 대한 조치

설명 – 지정된 버퍼의 크기보다 큰 데이터를 저장함으로써 실행 시 오류를 발생시키는 취약점

- 서버 제품군과 라이브러리의 경우, 사용하고 있는 제품군에 대한 최신 버그 리포트를 지속적으로 참고하여 최신 패치를 적용
- 자체 제작한 어플리케이션의 경우 HTTP 요청을 통해 사용자의 입력을 받아들이는 모든 코드를 검토하여 입력 값에 대해 적절한 크기를 점검하는지 확인

• CSRF(스크립트 요청 참조) 취약점에 대한 조치

설명 – 공격자가 사용자의 Cookie 값이나 Session 정보를 의도한 사이트로 보내거나 특정한 동작을 유발하는 스크립트를 글에 삽입하여 사용자가 게시물 등을 클릭할 경우 공격자가 원하는 동작이 실행되게 하는 취약점

- 헤더, 쿠키, 질의문, 폼 필드, 숨겨진 필드등과 같은 모든 파라미터들을 엄격한 규칙에 의해서 검증하여 HTML을 사용할 경우 태그 내에 html, ?, & 등이 포함되지 않도록 수정

• FI(Remote File Inclusion) 취약점에 대한 조치

설명 - URL이나 파일시스템 참조 등 외부 객체 참조를 사용하는 어플리케이션에서 입력파일 또는 입력 외부객체를 검증하지 않을 때 발생하는 취약점

- PHP 환경설정 파일 수정
※ PHP 4.x 이하 버전 : 'allow_url_fopen' 항목을 'off'로 변경
PHP 5.x 이하 버전 : 'allow_url_fopen' 항목과 'allow_url_include' 항목을 'off'로 변경
- 외부 사이트의 소스 실행이 반드시 필요한 홈페이지에 대해서는 선별적으로 해당기능을 허용

```
<VirtualHost www.abc.co.kr>
ServerAdmin webmaster@abc.co.kr
DocumentRoot /home/abc/public_html
ServerName www.abc.co.kr
php_admin_flag allow_url_fopen On ←추가
</VirtualHost>
```

• 파일 다운로드 취약점에 대한 조치

설명 - 웹 어플리케이션에서 상대경로를 사용할 수 있도록 설정되어 있는 경우, 상대경로 표시 문자열인“ ../”를 통해 허가되지 않은 상위경로로 이동하여 시스템 주요 파일, 소스코드 등 중요자료의 열람이 가능한 취약점

- 파일 다운로드 시 파일명을 직접 URL에서 사용하거나 입력받지 않도록 하며 게시판 이름과 게시물 번호를 이용하여 서버 측에서 데이터베이스 재검색을 통하여 해당 파일을 다운로드 할 수 있도록 수정
- 다운로드 위치는 지정된 데이터 저장소를 지정하여 사용하고 데이터 저장소 상위 디렉토리로 이동되지 않도록 설정
- PHP를 사용하는 경우 php.ini에서 magic_quotes_gpc를 On으로 설정하여 “.\\.”와 같은 역 슬래시 문자에 대응할 수 있도록 설정

• 백업 파일 노출 취약점에 대한 조치

설명 - 관리자가 홈페이지 상에서 작은 수정을 위해 기존 홈페이지 파일의 원본을 특정 확장자를 사용하여 저장할 수 있는데, 이러한 특정 확장자의 파일들이 서버에서 적절하게 처리되지 못할 경우 소스가 유출 될 수 있는 취약점

- 백업파일이 웹 서버에 존재하는 것은 소스 노출이나 DB정보 노출 등의 문제가 발생할 수 있으므로 웹 서버상의 불필요한 백업 파일들은 모두 삭제
- 홈페이지 서비스와 관련 없는 디렉토리(백업디렉토리 등)는 일반 사용자 접근이 불가능하도록 권한 설정

```
<Files ~“.bak$”>
Order allow,deny
Deny from all
</Files>
```

• 디렉토리 리스팅 취약점에 대한 조치

설명 – 웹 서버에는 현재 브라우징 하는 디렉토리의 모든 파일들을 사용자에게 보여 줄 수 있는 디렉토리 인덱스 기능이 존재하는데, 이런 설정이 활성화되어 있는 경우 공격자가 웹 어플리케이션의 구조를 파악할 수 있는 기회를 제공하게 되는 취약점

- 아파치 웹서버 : httpd.conf 파일에서 DocumentRoot 항목을 아래와 같이 수정 <Files ~ “%.bak\$”>

```
...
<Directory "/usr/local/www">
Options Indexes ← 제거한다
</Directory>
```

- IIS 웹서버 : IIS 관리메뉴의 기본웹사이트 등록정보에서 홈 디렉토리 검색부분 체크 해제

• 설정파일 및 환경변수 노출 취약점에 대한 조치

설명 – 웹 어플리케이션을 설정하기 위해 위치하는 파일들은 시스템이나 DB에 관련 한 많은 정보를 포함하고 있는데, 이 파일들이 공격자에게 노출될 경우 공격자에게 시스템의 많은 정보를 제공하게 되는 취약점

- 홈페이지 서비스와 관련없는 파일은 일반 사용자 접근이 불가능하도록 권한 설정

• 부적절한 HTTP Method 사용 취약점에 대한 조치

설명 – 원격 사용자가 DocumentRoot 디렉토리에 파일을 업로드하거나 수정하는 등의 행위를 하는 것을 제한해야 하는데, 이러한 제한이 적절히 이루어지지 않을 경우 홈페이지가 변조되거나 침해를 입을 수 있는 취약점

- PUT, DELETE Method 는 제한된 사용자만 가능하도록 하거나 아무도 사용하지 못하도록 아래와 같이 설정

```
...
<Directory "/home/*/public_html">
<Limit POST PUT DELETE>
Require valid-user
</Limit>
</Directory>
```

• 헤더 정보 노출 취약점에 대한 조치

설명 - 웹 서버에서는 응답 메시지의 헤더에 웹 서버 버전이나 응용 프로그램 버전 등을 전송하는데, 많은 정보들이 노출될 경우 알려진 취약점을 이용한 공격에 악용될 수 있는 취약점

- 아파치 웹 서버의 경우 httpd.conf 내용에 ServerTokens 지시자를 삽입하여 헤더에 의해 전송되는 정보를 최소화

• 오류 메시지 노출 취약점에 대한 조치

설명 - 오류 메시지가 공격자에게 무엇이 틀렸는지 알려주는 표시를 해주는 것으로 인해 공격자가 다양한 공격 방법을 시도할 수 있게 되는 취약점

- 별도의 오류 페이지를 제작하여 각각의 오류코드에 대해 제작된 하나의 오류 페이지로 Redirection 처리
- 아파치 웹 서버의 경우 httpd.conf 파일에서 아래와 같이 설정

```
ErrorDocument 404 /error_page.html
```

• 파일시스템 설정 오류 취약점에 대한 조치

설명 - 악성 프로그램을 /tmp, /dev/shm 등의 파일시스템 관련 디렉토리에 업로드하여 실행하는 형태로 공격에 악용될 수 있는 취약점

- /etc/fstab(파일시스템의 마운트 설정정보 파일) 내용을 아래와 같이 수정하여 해당 디렉토리의 실행권한을 제거(변경 후에는 mount 명령을 실행하여 적용해야 함)

```
none on /dev/shm type tmpfs (rw,noexec)
/dev/hda9 on /tmp type ext3 (rw,noexec,nosuid,nodev)
```

• 심볼릭 링크 취약점에 대한 조치

설명 - 웹 서버에서 심볼릭 링크를 이용해서 기존의 웹 문서 이외의 파일시스템에 접근하는 것이 가능한 취약점

- 아파치 웹서버 환경설정파일(httpd.conf)의 Options 지시자에서 심볼릭 링크를 가능하게 하는 옵션인 "FollowSymLinks"를 제거

• 최신 보안 패치 항상 유지

- 제로보드, 테크노트, 그누보드 등의 웹 어플리케이션에 대한 최신의 보안패치를 유지

민간부분 침해사고 대응안내서



04

제4장 **부록**

- 1. 사이버 위기 경보 48
- 2. WHISTL, Rootkit Hunter, Check Rootkit 사용법 54
- 3. 주요 용어 정리 55



1. 사이버 위기 경보

1. 사이버 위기 경보의 정의

사이버 위기 경보는 「국가사이버안전관리규정」 제11조에 의거, 각종 사이버공격에 체계적으로 대응하기 위해 파급효과, 피해 규모 등을 고려하여 위기상황에 따라 관심·주의·경계·심각 등의 단계로 발령하는 경보체계이다. 평상시에는 정상을 유지하다가 웜 바이러스, 해킹 등 사이버공격으로 인하여 민간분야 정보통신망 또는 인터넷 사용에 영향을 주거나 크게 우려되는 경우 침해사고 예방 및 피해 최소화를 위해 관심 → 주의 → 경계 → 심각 순으로 4단계로 발령한다.

구 분	내 용
정 상 (Green)	• 국내 민간 분야 인터넷 정상 소통 • 인터넷 소통 및 사용에 지장이 없는 – 웜/바이러스 등 악성코드 출현 탐지 – 신규 보안 취약점 또는 해킹 기법 등 발표 • 위험도가 낮은 국지성 이상 트래픽 발생 가능성 존재
관 심 (Blue)	• 위험도가 높은 웜·바이러스, 취약점, 해킹기법 및 공격코드 출현으로 인해 피해 가능성 증대 • 해외에서 침해사고 확산 또는 일부 국내유입 및 확산 가능성 증대 • 국내 인터넷 이상 트래픽 발생 가능성 증대 • 국내·외 정치·군사적 위기상황 조성 등 사이버위협 징후 탐지활동 강화 필요
주 의 (Yellow)	• 웜·바이러스, 해킹 등으로 국지적 피해 발생 • 국지적인 인터넷 소통장애, 인터넷 관련 서비스에 장애가 발생되거나 매우 우려되는 경우 • ISP/IDC, 일반 사용자, 기업 등의 긴급대응 및 국내·외 정치·군사적 위기발생 등 사이버안보 위해 가능성 고조
경 계 (Orange)	• 복수 ISP망 또는 주요 정보통신 기반시설의 피해 발생 • 해킹 및 신종위협으로 주요기업 및 포털, 연구소 등의 민간부문에 중대한 피해 발생 • 웜·바이러스, 해킹 등 침해사고로 민간부문에 다수 기업, 이용자 등 피해 발생 • 상황 해결을 위해 민관 각 분야의 협조 및 공동 대응이 필요한 상황
심 각 (Red)	• 국내 인터넷 전 분야에 소통 장애 발생 • 주요 정보통신기반시설의 피해로 인하여 대국민 서비스 지장 발생 • 민간 부분 전반에 대규모 침해사고 피해발생 • 국가적 차원에서 공동 대처해야 할 필요성이 있는 상황

※ 위험 정도가 낮은 웜·바이러스, 해킹기법, 보안취약점이 발견된 경우는 위기경보 이전 단계인 “정상”(Green) 수준으로 간주

〈표 4-1〉 경보의 단계

2. 사이버 위기 경보 체계

가. 사이버 위기 경보 발령 주체

국가정보원장은 사이버공격에 대한 체계적인 대응 및 대비를 위하여 사이버공격의 파급영향, 피해규모 등을 고려하여 관심·주의·경계·심각 등 수준별 경보를 발령할 수 있다. 다만, 민간 분야에 대하여는 미래창조과학부장관이 경보를 발령하고, 국방 분야에 대하여는 국방부장관이 경보를 발령한다.

나. 민간분야 사이버 위기 경보 발령 절차

한국인터넷진흥원 인터넷침해대응센터는 위기 징후를 포착하거나 위기 발생이 예상되는 경우, 1차 위기평가회의(의장 : 사이버침해대응본부장)를 개최하고, 위기수준을 평가한다.

미래창조과학부는 인터넷침해대응센터에서 평가한 위기수준이 사이버 위기 경보 발령 수준으로 평가되는 경우 위기경보(관심, 주의)를 발령하고, 범정부 차원의 위기경보(경계, 심각) 발령이 필요하다고 판단되는 경우 2차 위기평가회의(의장 : 정보통신정책실장)를 개최하고, 2차 위기평가회의 결과에 따라 사이버 위기 경보를 상향 발령한다. 단, 경보발령은 국가 차원에서의 효율적인 경보 업무를 수행하기 위하여 국가안보실, 국가정보원, 국방부와 사전에 협의하고 있다.

경보 발령 시 미래창조과학부는 언론 등을 통해 국민을 대상으로 경보내용을 전파하고, 인터넷침해대응센터는 주요 ISP, 백신·보안 업체 등에 경보상황을 신속히 전파한다.

다. 위기경보 발령 과정

경보 발령은 정보의 수집·탐지 → 분석·협의 → 전파·발령의 순서로 이루어진다.

- (1) 수집·탐지 : 국내외 인터넷트래픽 및 취약점 정보, 백신업체 및 S/W 벤더 등으로부터 인터넷 트래픽 통계 및 웜·바이러스 정보 등 침해사고 관련 정보를 수집·탐지하는 과정
- (2) 분석·협의 : 수집된 정보를 자동 및 수동 분석하고 협의하여 인터넷 경보 단계를 결정하는 과정
- (3) 전파·발령 : 경보 상태를 다양한 전파수단을 이용하여 알림으로써 침해사고를 사전 예방하고 사고 발생 시 신속히 대응하는 과정
- (4) 대응·복구 : 침해사고 피해 원인을 분석하고 피해 시스템을 복구하는 과정



〈그림 4-1〉 경보 발령 과정

현재의 경보 단계는 다음 <표4-2>와 같은 방법으로 인지할 수 있다.

구 분	인터넷 접속이 가능한 경우	인터넷 접속이 불가능한 경우
가입자 (개인/PC방 등)	■ 인터넷 이용 ① 보호나라&KrCERT 홈페이지 접속 (http://www.boho.or.kr) ② 초기화면의 경보 안내표시 확인	■ 방송, 신문 등 언론 매체 이용 ■ 한국인터넷진흥원 신고센터에 전화문의 ※ 민원상담 110 : ☎ (국번없이) 110, 전화 연결
기업 (직원 및 정보보호 담당자)		■ 인터넷침해대응센터 종합상황실의 상황 전파내용 참고 ※ TRS, FAX, 전화 등을 통하여 통보됨
ISP/IDC		

〈표 4-2〉 경보 단계의 인지방법

3. 민간분야 사이버 위기 경보 단계별 조치사항

기업의 정보보호/서버/네트워크 관리자가 경보 각 단계별로 점검 및 조치하여야 하는 침해사고 예방 및 대응요령은 아래 <표 4-3>와 같다

단 계	정 상 (Green)	관 심 (Blue)	주 의 (Yellow)	경 계 (Orange)	심 각 (Red)
대 응 요 령	피해발생 대비 대응 체계 마련 및 훈련	기업내부 직원, 서비스 고객, 유관 기관에 “관심” 경보 전파	기업내부 직원, 서비스 고객, 유관 기관에 “주의” 경보 전파	기업내부 직원, 서비스 고객, 유관 기관에 “경계” 경보 전파	기업내부 직원, 서비스 고객, 유관 기관에 “심각” 경보 전파
	주요 서버 및 관리 시스템, 보안 장비, 정책 등 정기 점검	주요 서버 및 관리 시스템, 보안 장비, 정책 등 긴급 점검	모든 서버 및 관리 시스템, 보안 장비, 정책 등 긴급 점검	모든 서버 및 관리 시스템, 보안 장비, 정책 등 수시 점검	모든 서버 및 관리시 스템, 보안 장비, 정책 등 수시 점검
	보안 패치(OS, 응용 S/W) 주기적 적용	보안 패치 긴급 적용	보안 패치 긴급 적용	취약S/W의 사용 중단 검토	취약S/W의 사용 중단
	백신, 바이러스 윌 주기적 업데이트	백신, 바이러스 윌 상시 업데이트	백신, 바이러스 윌 업데이트 및 감염여부 점검	악성코드 감염PC LAN에서 분리	기업내 PC사용 최소화
	서비스 포트 모니터링	기업에서 사용 하지 않는 서비스 포트 차단 검토	기업에서 사용 하지 않는 서비스 포트 차단	사이버 공격 관련 이 상 포트 차단 검토	사이버 공격 관련 이상 포트 차단
	악성코드 등 침해 사고 동향 파악	KISA 보안공지 주시	KISA 보안공지 및 언론보도 주시	정부의 상황전파 및 보안권고 반영	관련기관 사고 대응 적극 협조
	침해사고대응팀 비상연락망 수립	침해사고대응팀 비상연락망 점검	침해사고대응팀 가동	침해사고대응팀 확대 운영	침해사고대응팀 24시간 운영
		※“정상”단계대응 요령 포함	※“관심”단계대응 요령 포함	※“주의”단계대응 요령 포함	※“경계”단계대응 요령 포함

<표 4-3> 경보 단계별 대응 요령

가. “정상” 시 예방활동

- 기업 내 주요 시스템 및 네트워크, 보안 체계를 모니터링하고 주기적으로 점검한다.
- 비상상황에 대비하여 장애 대책을 수립하고 훈련 등을 통해 숙지한다.
- 주기적으로 주요 시스템 로그 분석, 취약성 점검도구 등을 통하여 해킹 또는 침입 흔적이 없는지 점검한다.
- 보안정책을 주기적으로 점검, 필요시 개선토록 한다.
- 주기적으로 운영체제와 응용소프트웨어에 대한 업데이트를 확인하고 새로운 보안 패치가 발표되었을 경우 신속하게 적용할 수 있는 체제를 마련한다.
- 사용 중인 백신 프로그램, 바이러스 윌 등 보안 솔루션을 주기적으로 업데이트 한다.
- 서비스 중인 네트워크 포트는 상시 모니터링하고 이상 발생 시 즉시 대응하기 위한 체계를 갖추어야 한다.
- KISA 보호나라 및 언론보도 등을 통해 최근 국내외 침해사고의 동향을 파악한다.
- 유사시 신속한 대응을 위한 자체 침해사고대응팀을 구성하고 비상연락망을 수립한다.

나. “관심”경보 발령 시 대응요령

- 기업 내부 직원 및 사용자들에게 “관심” 경보를 전파하여 피해가 확산되지 않도록 한다.
- 주요 시스템 및 보안장비를 긴급히 점검하여 이상 발생 시 즉시 조치하여야 한다.
- 사용 중인 운영체제 및 응용프로그램의 업데이트 여부를 수시로 확인하고 신규 보안패치 발표시 즉시 적용한다.
- 사용 중인 백신 프로그램, 바이러스 윌 등 보안 솔루션의 업데이트 여부를 상시 확인하고 적용한다.
- 기업에서 사용하지 않는 서비스 포트 및 프로토콜의 차단을 검토한다.
- KISA에서 발표하는 보안공지를 수시로 검토하여 해당 사항이 있을 경우 시스템 운영에 반영토록 한다.
- 유사시 즉시 대응을 위해 침해사고대응팀의 비상연락망을 점검한다.

다. “주의”경보 발령 시 대응요령

- 기업 내부 직원 및 사용자들에게 “주의” 경보를 전파하여 비상상황에 대비할 수 있도록 한다.
- 운영 중인 모든 시스템 및 보안장비를 긴급히 점검하고 이상 발생 시 즉시 조치한다.
- 지속적으로 운영체제 및 응용프로그램의 신규 업데이트 및 보안패치 발표 여부를 확인하고 신속히 적용한다.
- 백신 프로그램 또는 바이러스 율을 최신버전으로 업데이트 하고 기업 내 운영PC 대상 악성코드 감염여부를 점검한다.
- 기업에서 사용하지 않는 서비스 포트 및 프로토콜은 차단하여 피해를 예방한다.
- KISA 보안공지 및 언론보도를 주기적으로 주시하여 주요 보안 조치사항을 파악하고 필요시 기업 내 적용한다.
- 침해사고대응팀을 가동하여 상시 대응체계를 유지한다.

라. “경계”경보 발령 시 대응요령

- 기업 내부 직원 및 사용자들에게 “경계” 경보를 전파하고 서비스 통제와 관련된 상황을 사전에 안내하여 대비할 수 있도록 한다.
- 보안 취약점이 존재하는 프로그램의 사용 여부를 점검하고 대체 프로그램을 마련하거나 해당 프로그램의 사용 중단을 검토한다.
- 악성코드에 감염 된 PC는 인터넷 연결을 차단하여 피해확산을 방지한다.
- 기업 내 전체 네트워크를 모니터링 하고, 사고 발생에 악용될 수 있는 포트 및 프로토콜에 대해 사고가 확산될 경우 차단할 수 있도록 준비한다.
- 정부 및 유관기관의 상황전파, 보안권고사항을 적극 이행하고 대응조치에 필요한 사항은 적극 협조한다.
- 침해사고대응팀, 고객지원팀 등 자체 긴급 대응반을 확대 가동하고 유관기관과 공동 대응한다.

마 “심각”경보 발령 시 대응요령

- 관련된 기관 및 사용자들에게 “심각” 경보를 전파하고 침해사고대응팀, 고객지원팀 등을 포함한 비상대책반을 24시간 가동 한다.
- 보안 취약점이 존재하는 프로그램은 사용을 중단한다.
- 악성코드 피해 확산 방지를 위해 기업 내 PC의 사용을 최소화 한다.
- 사고 발생에 악용되는 포트 및 프로토콜은 차단하여 사용을 제한한다.
- 관련기관의 사고 대응에 적극 협조한다.

2. WHISTL 및 Rootkit Hunter, Check Rootkit 사용법

1. WHISTL 설치 및 사용

– 다운로드 : <http://www.boho.or.kr> ▶ 웹 보안 서비스 ▶ 휘슬

- whistl 압축해제 및 실행권한 설정
[root@linux .whistl]# tar xzvf Whistl_Linux.tgz
[root@linux .whistl]# chmod 755 whistl_kernel_2.6
※ kernel 2.4.x 의 경우 whistl_kernel_2.4에 실행권한(755) 부여
- 실행 [root@linux .whistl]# ./whistl_kernel_2.6

2. Rootkit Hunter 설치 및 사용

– 다운로드 : <https://sourceforge.net/projects/rkhunter/>

- 압축해제 [root@linux root]# tar xzvf rkhunter-1.4.2.tar.gz
[root@linux root]# cd rkhunter-1.4.2
- 설치 [root@linux rkhunter-1.4.2]# ./installer.sh --layout default --install
- 업데이트 [root@linux rkhunter-1.4.2]# rkhunter --update
- 실행 [root@linux rkhunter-1.4.2]# rkhunter -c

3. Check Rootkit 설치 및 사용

– 다운로드 : <http://www.chkrootkit.org>

- 압축해제 [root@linux root]# tar xzvf chkrootkit.tar.gz
[root@linux root]# cd chkrootkit
- 설치 [root@linux chkrootkit]# make sense;
- 실행 [root@linux chkrootkit]# ./chkrootkit -q
※ -q 옵션 : rootkit에 감염된 파일(프로세스)만 출력

3. 주요 용어 정리



감염PC 사이버치료체계

자신도 모르게 침해사고를 유발하는 감염PC 이용자에게 팝업창을 통해 악성코드 감염사실을 알리고, 치료수단을 제공하는 서비스



디도스 공격 (Distributed Denial of Service)

공격자(해커)가 악성코드에 감염된 다수의 PC를 이용하여 대량의 유해 트래픽을 특정 시스템에 전송함으로써 네트워크 및 시스템의 과부하를 유발하여 정상적인 서비스를 방해하는 사이버 공격

디도스 사이버대피소

자체적으로 DDoS 대응이 어려운 중소기업을 대상으로 대피소에서 공격 트래픽을 방어하고 정상 이용자의 접속을 웹사이트로 전달해주는 DDoS 공격 방어 서비스



랜섬웨어(Ransomware)

몸값을 뜻하는 ransom과 제품을 뜻하는 ware의 합성어로 사용자의 동의 없이 컴퓨터에 불법으로 설치되어서, 사용자 문서 등을 암호화하여 돈을 요구하는, 사용자의 파일을 인질로 잡는 악성프로그램

루트킷(Rootkit)

루트킷은 해커가 설치한 악성코드(트로이목마, 악성봇 등)가 백신이나 PC 사용자에게 발각되지 않도록 숨겨주는 역할을 함.

대부분의 루트킷은 일반 프로그램이 동작하는 계층보다 더 하위계층, 즉 커널이라는 운영체제 핵심 부분에 숨어서 동작하여 탐지·분석이 어려움.

※ '커널 루트킷', '커널 감염형 악성코드'라고 불리기도 함

로그분석

로그(log)는 시스템의 데이터 처리 내용이나 접속현황 등 다양한 운용 정보를 시간의 흐름에 따라 기록한 정보로써 로그분석을 통해 침해사고 발생 시점, 침입경로, 공격자 추적 등 침해사고 원인분석을 위한 단서를 확보할 수 있음

```
[root@cal AWStats]# wget http://prdownloads.sourceforge.net/awstats/awstats-7.0.tar.gz
--2012-02-01 09:32:12-- http://prdownloads.sourceforge.net/awstats/awstats-7.0.tar.gz
Resolving prdownloads.sourceforge.net... 216.34.181.59
Connecting to prdownloads.sourceforge.net[216.34.181.59]:80... connected.
HTTP request sent, awaiting response... 301 Moved Permanently
Location: http://downloads.sourceforge.net/project/awstats/AWStats/7.0/awstats-7.0.tar.gz [following]
--2012-02-01 09:32:13-- http://downloads.sourceforge.net/project/awstats/AWStats/7.0/awstats-7.0.tar.gz
Resolving downloads.sourceforge.net... 216.34.181.59
Reusing existing connection to prdownloads.sourceforge.net:80.
HTTP request sent, awaiting response... 302 Found
Location: http://cdnetworks-kr-1.dl.sourceforge.net/project/awstats/AWStats/7.0/awstats-7.0.tar.gz [following]
--2012-02-01 09:32:14-- http://cdnetworks-kr-1.dl.sourceforge.net/project/awstats/AWStats/7.0/awstats-7.0.tar.gz
Resolving cdnetworks-kr-1.dl.sourceforge.net... 211.39.135.162
Connecting to cdnetworks-kr-1.dl.sourceforge.net[211.39.135.162]:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1254327 (1.2M) [application/x-gzip]
Saving to: 'awstats-7.0.tar.gz.1'
```



명령 · 제어 서버 (C&C, Command and Control)

해커가 악성코드 등으로 감염시킨 좀비PC를 관리하고 DDoS 등의 공격명령을 내리기 위한 목적으로 구축한 서버

모바일 응급 사이버치료체계

자신도 모르게 악성앱에 감염되어 피해가 발생하는 스마트폰을 대상으로 감염사실을 알리고, 치료방안을 제공하는 서비스

민관합동조사단

정보통신망에 중대한 침해사고 발생 시 원인조사, 기술지원 및 재발방지대책 마련을 목적으로 미래창조과학부에서 구성하는 합동조사단

- ※ 조사단은 민간분야 보안전문가들로 구성된 '사이버보안전문단' 구성원 중에서 20명 이내 선발
- ※ 『정보통신망 이용촉진 및 정보보호 등에 관한 법률』제48조의4(침해사고 원인분석 등)
- ※ 『정보통신망 이용촉진 및 정보보호 등에 관한 법률 시행령』제59조(민 · 관합동 조사단의 구성 등)



바이러스 (Virus)

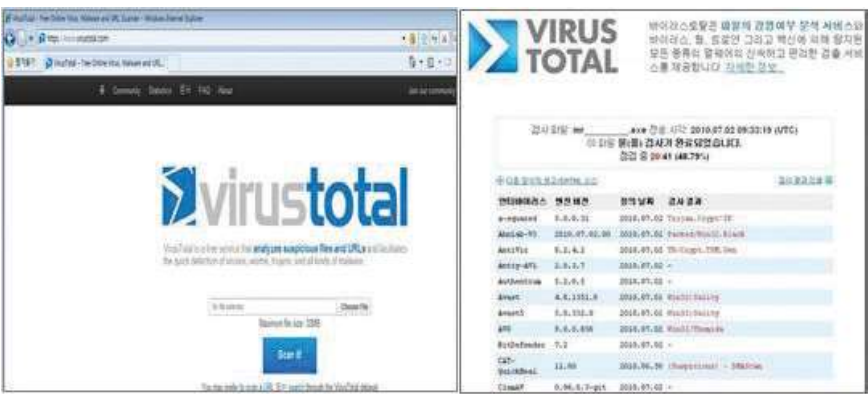
정상적인 실행파일에 달라붙어(기생) PC를 다운시키거나 파일을 파괴하는 등 컴퓨터의 운영을 방해하는 악성코드의 일종. 감염대상이 되는 파일이 있어야 하며, 자신을 복제하는 기능은 없음.

※ 주로 '80~'90년대에 많이 발생했으며, 플로피디스크 등을 통해 감염

바이러스 토탈(Virus Total)

구글이 운영하는 악성코드 점검 사이트

해당 사이트에 의심스러운 파일을 업로드하면, 국내외 40여개 백신프로그램으로 해당 파일에 대해 악성 여부를 검사하여 그 결과를 실시간으로 제공



〈웹서버에 기록된 로그 화면 사례〉

백도어(Backdoor)

일명 '개구멍'과 같이 허가되지 않은 비정상적인 출입통로를 의미

해커가 이용자 몰래 컴퓨터에 접속하여 악의적인 행위를 할 수 있도록 출입통로 역할을 해주는 악성코드

버퍼 오버플로우(Buffer Overflows)

컴퓨터상에서 특정 프로그램에 할당된 메모리 영역을 초과하는 크기의 데이터를 입력시킴으로써 발생하는 취약점을 이용한 해킹기법

버퍼의 크기보다 더 많은 데이터를 입력하면 버퍼가 넘쳐 메모리의 다른 영역으로 침범하게 되는데, 이때 프로그램이 오류를 일으켜 해커가 원하는 공격코드가 실행되도록 하는 방식

※ 버퍼 : 시스템이 연산 작업에 필요한 데이터들을 일시적으로 저장하는 메모리상의 저장 공간

보이스피싱(Voice Phishing)

음성(Voice)과 개인정보(Private Data), 낚시(Fishing)의 합성어. 전화로 수사기관 · 정부기관 · 금융기관 등을 사칭해 돈을 송금하게 하거나 개인정보 · 금융정보 등을 탈취하는 사기수법



소프트웨어 보안약점

소프트웨어 결함, 오류 등으로 해킹 등 사이버공격을 유발할 가능성이 있는 잠재 적인 보안취약점

소프트웨어 신규 취약점 신고 포상제

「소프트웨어산업 진흥법」에 따른 소프트웨어의 최신 버전에 대한 신규 보안 취약점을 최초로 신고한 자에게 포상금을 지급하는 제도 (단, 대한민국 국적자에 한함)

스미싱(Smishing)

문자메시지(SMS)와 피싱(Phishing)의 합성어. 스마트폰 문자메시지를 통해 악성앱을 설치하도록 유도하여 개인 정보, 금융정보 등을 탈취하는 사기 수법

신규 취약점(Zero-Day Vulnerability)

최신 버전의 소프트웨어에서 동작하는 취약점으로 해당 취약점을 제거하는 보안패치가 발표되지 않은 상태의 취약점



악성 앱(Malicious App)

스마트폰에 설치되어 과금유발, 정보유출, 파일을 조작하여 이용자에게 정신적 · 금전적 피해를 유발시키는 프로그램

악성봇(Bot)

해커가 원격에서 조종할 수 있도록 좀비PC를 만드는 악성코드이며, PC가 악성봇에 감염되면, 해커의 조종에 따라 PC 사용자도 모르는 사이에 스팸발송, 악성코드 유포, 분산 서비스 거부 공격(DDoS) 등에 악용될 수 있음

악성코드 은닉사이트

악성코드 자체 또는 악성코드를 유포하는 주소(URL)를 숨기고 있는 홈페이지로, 보안에 취약한 이용자 PC 가 해당 홈페이지에 접속 시 악성코드에 감염될 우려가 있음

역공학(Reverse Engineering)

정보보호 분야에서는 주로 악성코드의 기능이나 동작을 분석할 때 사용되며, 소스코드가 제공되지 않는 프로그램을 역으로 분석하여 기능을 추적하는 행위를 의미함.
시스템이나 프로그램 등을 개발하기 위하여 설계-구현-테스트 등 단계적으로 절차를 진행하는 것에 반대되는 개념

웜(Worm)

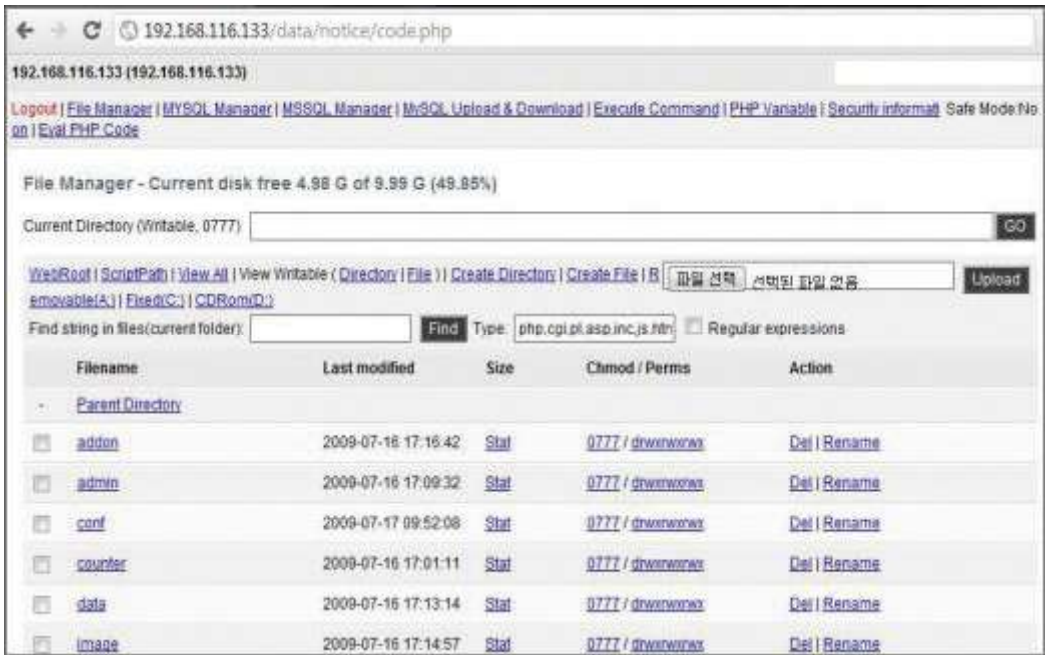
다른 파일에 기생하지 않고 독립적으로 자신을 복제하여 확산함으로써 전파속도가 매우 빠른 특징을 가지는 악성코드 유형. 주로 메일이나 네트워크 공유폴더 등을 통해 전파되고 시스템과 네트워크에 부하를 높이는 증상을 보임

웹 해킹(Web Hacking)

웹 서비스와 관련된 구성 요소들을 공격하여 이용자 권한이나 관리자 권한을 획득하는 행위를 의미
웹은 누구나 쉽게 접속할 수 있도록 구성되고 웹 게시판이나 DB 등 다양한 어플리케이션들이 연동되기 때문에 취약점 발생 가능성이 높고 해킹 위험도 큼

웹셸(Web Shell)

공격자가 원격으로 웹서버에 악의적인 명령을 실행할 수 있도록 작성한 웹스크립트 파일로, 웹서버 내 취약점을 악용하여 업로드 됨



< 웹셸을 실행한 화면 예시 >

이미지 분석

시스템의 하드디스크와 완벽히 같은 사본 파일을 만드는 과정을 이미징(Imaging) 이라고 하며, 해당 사본 파일을 분석하는 것을 의미 숨김파일, 임시파일, 손상/삭제 파일의 잔여정보가 그대로 존재하고, 원본 증거를 보호할 수 있는 장점 제공

구분	디스크복사	디스크이미징
저장방식	디스크 내부의 파일들을 읽어서 순차적으로 복사를 실시	디스크의 첫 번째 위치에서부터 끝 위치까지 복사를 실시
저장대상	파일과 디렉터리 단위의 정보	디스크의 모든 물리적 섹터
정보손실	시스템 파일, 사용 중인 파일은 내용을 읽을 수 없으므로 복사가 실패	하드웨어의 물리적 오류를 제외하고 디스크의 모든 정보를 복사
파일복구	삭제 파일의 정보를 수집하지 않음	디스크 섹터에 삭제파일 정보가 남아있는 경우 복구 가능

〈 웹셀을 실행한 화면 예시 〉

익스플로잇(Exploit)

해커가 컴퓨터 소프트웨어(또는 하드웨어)의 취약점을 이용해 악성(개인정보 탈취, 악성코드 유포 등)행위를 하기 위해 제작한 악성 프로그램

인터넷 연동구간(IX, Internet eXchange)

ISP(인터넷 서비스 제공자)간의 인터넷 트래픽을 원활하게 소통시키기 위한 인터넷 연동 서비스로, ISP간의 상호 접속을 목적으로 국내 ISP간 트래픽을 교환하는 국내 연동구간과 해외 ISP와 연결되는 국제 연동구간이 있음



정보공유 · 분석센터 (ISAC : Information Sharing & Analysis Center)

통신, 금융, 행정 등 분야별 주요정보통신기반시설에 대한 해킹 및 사이버테러 등 전자적 침해행위에 관한 정보를 분석하고, 침해사고 발생시 대응요령 및 지침을 신속하게 전파하는 등 사이버 공격에 효과적으로 예방, 탐지, 대응하도록 지원할 수 있는 시스템 및 조직

정보보호 관리체계 (Information Security Management System)

기업 또는 조직이 각종 위협으로부터 주요 정보자산을 보호하기 위해 정보보호관리 절차를 체계적으로 수립하여 지속적으로 관리 · 운영하는 종합적인 체계('13년부터 ISMS 인증제도가 의무화됨)

※ 인증심사 기준 : 총 104개 통제사항으로 구성(정보보호 5단계 관리과정 요구사항 12개 통제사항, 정보보호대책 13개 분야 92개 통제사항)

정보보호의 날(매년 7월 둘째 주 수요일)

범부처 합동으로 사이버 공격을 예방하고 국민들의 정보보호 생활화를 위해 지정된 정부 주관 기념일('12. 10. 22, 대통령령)로써 정보보호의 날(매년 7월 둘째 주 수요일)에는 정보보호의 날 기념식을 개최

정보통신기반시설

국가안전보장 · 행정 · 국방 · 치안 · 금융 · 통신 · 운송 · 에너지 등의 업무와 관련된 전자적 제어 · 관리시스템 및 정보통신망

좀비PC(Zombie PC)

악성코드에 감염됐지만 스스로 인지하지 못한 채 스팸 발송, DDoS 공격 등 해커에 의해 원격조종당하는 PC

주요정보통신기반시설

중앙행정기관의 장이 소관분야의 정보통신기반시설 중 전자적 침해행위로부터 보호가 필요하다고 인정하여 지정한 시설

※ 지정 기준(정보통신기반보호법 제8조 관련) : ① 업무의 국가사회적 중요성, ② 정보통신기반시설에 대한 의존도, ③ 다른 정보통신기반시설과의 상호 연계성, ④ 침해사고 발생시의 피해규모 및 범위, ⑤ 침해 사고 발생가능성 또는 복구의 용이성

지능형 지속 공격 (APT, Advanced Persistent Threat)

특정 대상을 겨냥해 명확한 목표를 두고 지능적, 지속적으로 은밀히 공격을 가하여 정보를 수집하고 유출하는 해킹기법



※ 주요 대상 : 정부기관, 사회기반 산업시설, 금융, 정보통신 기업 등

※ 대표적 사례 : 스텔스넷('10년), 3 · 4 DDoS 공격('11.3월), 농협전산망 마비사고('11.4월), 3 · 20 사이버공격('13.3월), 한수원 내부정보 유출('14.12월) 등

㉔

침해사고대응팀(CERT)

인터넷상에서 침해사고 발생 시 대응 및 예방 업무를 담당하는 조직으로 독립된 기관, 회사 내 소속된 부서 등 그 형태는 다양함. 특히, 국가 전체에 대한 침해사고 대응 업무를 하는 조직을 국가침해사고대응팀 이라고 부름

㉕

캐슬(CASTLE)

홈페이지 취약점을 통한 침입시도 및 공격코드를 차단할 수 있는 보안도구

키로거(Keylogger)

사용자의 키보드 입력값을 로그파일로 저장하여 해커측으로 전송하는 악성 프로그램

※ 사례 : 키로거를 실행시켜 놓고 네이버에 로그인하면 아이디, 비밀번호가 노출됨



〈키로거 실행 및 로그인 정보 입력 사례〉



트로이목마(Trojan)

그리스 신화에서 유래된 명칭으로, 컴퓨터에 숨어 있다가 사용자의 정보를 몰래 유출하는 악성코드의 일종이며, 정상적인 파일(게임, 응용S/W 등)에 포함되어 함께 설치되는 경우가 많음



파밍(Pharming)

이용자 PC에 악성코드를 감염시키거나, 해킹 등으로 도메인 네임 시스템(DNS) 등을 변조함으로써 사용자가 정상 사이트 주소를 입력해도 가짜(피싱) 사이트로 접속하게 하여 개인정보, 금융정보 등을 탈취하는 수법

피싱(Phishing)

개인정보(private data)와 낚시(fishing)를 합성한 용어로, 불특정 다수에게 이벤트 당첨이나 개인정보 확인 요청 등의 내용을 담은 거짓 이메일을 보내거나 국가기관이나 금융기관 등을 사칭하는 가짜 사이트를 만들고 로그인이나 카드결제를 하는 것처럼 속여 정보를 빼가는 온라인 사기수법



해킹(Hacking)

컴퓨터 또는 시스템의 정당한 접근권한 없이 또는 허용된 접근권한을 초과하여 정보통신시스템에 침입하는 행위 (정보통신망 이용촉진 및 정보보호 등에 관한 법률)제48조 1항, 3항에 의한 정의

해킹방어대회(Hacking Defence & Contest: HDCon)

국내 정보보호 인력의 해킹 방어수준 측정, 윤리적 해커 양성 등을 위해 KISA가 개최해 온 국내에서 가장 전통 있는 해킹방어대회

※ 공격보다 사고분석 및 방어에 중점을 두고 문제를 해결하는 국내 유일한 대회

허니넷

다수의 IP를 이용하여 보안에 취약한 PC 환경을 구축 후, 인터넷에 노출시켜 악성코드를 채증하는 시스템

홈페이지 변조(Homepage Defacement)

홈페이지 메인 화면이 비정상적인 다른 이미지로 보이도록 해커가 변조한 것으로 특정 기업이나 조직의 이미지, 신뢰성 등을 실추시키려는 목적으로 많이 발생

휘슬(WHISTL)

홈페이지에 숨겨진 해킹프로그램(웹셀)을 탐지할 수 있는 보안도구

A

APCERT(Asia Pacific Computer Emergency Response Team)

아태침해사고대응팀협의회, 아태지역 내 침해사고대응팀 연합

ActiveX

ActiveX는 MS사의 인터넷브라우저(IE)에서만 동작되는 기술로 이용자가 웹서비스를 이용하는데 필요한 응용 프로그램을 PC에 자동 설치할 수 있도록 지원하는 비표준 기술

C

CC(Common Criteria)

IT제품의 보안성을 평가하기 위한 국제표준(ISO/IEC 15408)

CCRA(Common Criteria Recognition Arrangement)

한, 미, 일 등 25개 회원국이 CC에 따른 평가·인증 받은 제품을 상호인정 하는 국제 협정

CERT(Computer Emergency Response Team)

침해사고대응팀을 일컫는 말로, CERT/CC에서 로열티를 갖고 있음

CONCERT(CONsortium of CERTs, 한국침해사고대응팀협의회)

국내 정보통신망 침해사고대응팀(CERT) 간의 정보교류, 기술공유, 업무협조 등의 협력체계를 마련하기 위해 결성된 국내 CERT 협의체

※ 1996년 결성, 2005년 사단법인으로 재출범

CSIRT(Computer Security Incident Response Team)

침해사고대응팀을 일컫는 말로, CERT/CC에서 로열티를 갖고 있는 CERT(Computer Emergency Response Team)을 대체하기 위한 용어로 널리 사용 중

C-TAS(Cyber Threat Analysis & Sharing System)

3.20, 6.25 등 대규모 사이버 공격에 대한 후속조치로, 위협정보 수집·분석·공유 절차를 체계화하여 신속히 대응하기 위해 구축하였으며 악성코드, 취약점, 침해사고 등 위협정보를 체계적으로 수집·저장하고 정보를 종합적으로 분석하여 유관기관과 신속하게 공유하는 시스템

D

DNS(Domain Name System)

숫자로 이루어진 인터넷주소(IP)를 사용자가 알기 쉽게 문자로 표현된 도메인네임으로, 문자로 표현된 도메인네임을 다시 컴퓨터가 인식할 수 있도록 숫자로 표기된 IP 주소로 변환해 주는 시스템

DNS싱크홀

зом비PC가 C&C와 연결을 시도할 때 해당 트래픽을 우회시켜 해커가 C&C를 통해 зомбиPC를 조종하지 못하도록 차단하는 시스템

F

FIRST(Forum for Incident Response and Security Teams)

국제침해사고대응팀협의회. 전 세계 최대 규모의 침해사고대응팀 연합

G

GCCD(Global Cybersecurity Center for Development, 글로벌정보보호센터)

WB(세계은행) 회원국의 정보보호 역량 강화를 목적으로 한국정부와 WB가 협력하여 인천(송도)에 설립

H

HTML5(Hyper Text Markup Language 5)

차세대 웹문서 표준('15년 확정)으로서, 텍스트와 하이퍼링크만 표시하던 HTML이 멀티미디어 등 다양한 애플리케이션까지 표현·제공하도록 진화한 “웹 프로그래밍 언어”

P

PIMS(Personal Information Management System, 개인정보보호 관리체계)

기업이 각종 개인정보 유출 위험으로부터 개인정보를 보호하기 위해 보호대책을 수립해 체계적·지속적으로 관리·운영하는 종합적인 체계

R

Rooting(루팅)

안드로이드 운영체제를 탑재한 모바일 기기에서 root 계정을 획득하는 것

※ root 계정 : 모든 파일과 프로그램에 접근 가능한 권한을 가진 슈퍼유저(superuser)가 사용하는 계정

S

SQL 인젝션(SQL Injection)

SQL을 사용하는 응용프로그램에서 S/W개발자가 생각하지 못한 입력 및 조작으로 인해 발생하는 오류

※ SQL(Structured Query Language) : 사용자가 데이터베이스(DB)에 질의, 삽입, 삭제 등의 작업을 수행할 수 있도록 해주는 표준 데이터베이스 질의 언어



미래창조과학부



한국인터넷진흥원